

ICS410

模試 1

Question 1 of 82

Which of the following is best verified through the use of hashing?

- ☐ Availability
- ☒ **Integrity**
- ☐ Confidentiality

全82問中1問目

ハッシュ関数を用いることで最も適切に検証できるのは、次のうちどれですか？

- ☐ 可用性
- ☒ 誠実さ
- ☐ 機密保持

✓ その通りです

ハッシュ化は、ファイルが改ざんされていないことを検証するために使用される一方向関数です。ハッシュ化は元に戻せないため、データの機密性を保つ目的での送信には適していません。データがハッシュ化されると、元の形式では利用できなくなります。

Question 2 of 82

What is an advantage of using virtualization in an ICS environment?

- ☐ Simplifies troubleshooting and monitoring
- ☐ May be safely managed from any zone in the organization
- ☐ Works well across different trust zones on a single host
- ☒ **Makes system patching and backups easier**

全82問中2問目

ICS環境において仮想化を利用する利点は何ですか？

- ☐ トラブルシューティングと監視を簡素化します
- ☐ 組織内のどのゾーンからでも安全に管理できます
- ☐ 単一ホスト上の異なる信頼ゾーン間でも正常に動作します
- ☒ システムのパッチ適用とバックアップが容易になります

✓ その通りです

ICS環境における仮想化の利点としては、リソースの統合、冗長性、テストおよびトレーニング環境の構築、パッチ適用とバックアップの管理の容易化などが挙げられます。仮想化は、同一ホスト上の異なる信頼ゾーンにまたがって構築すべきではありません。信頼ゾーンからのみ管理されるべきです。場合によっては、仮想化によってトラブルシューティングやシステム監視の複雑さが増すこともあります。

Question 3 of 82

What must an attacker identify about a wireless network in order to perform a DoS attack against it?



The frequencies

- ☐ A previously used MAC address
- ☐ The encryption algorithm
- ☐ A session key

全82問中3問目

攻撃者が無線ネットワークに対してDoS攻撃を実行するには、そのネットワークについてどのような情報を特定する必要がありますのでしょうか？



周波数



以前使用されたMACアドレス



暗号化アルゴリズム



セッションキー



その通りです

通信に使用される周波数を特定した攻撃者は、その周波数帯にノイズを発生させることで、DoS攻撃を実行できる。MACアドレス、アルゴリズム、セッションキーを知っていることは、DoS攻撃に特有のものではない。

Question 4 of 82

A team has verified the version of firmware they will be using in their production HMI's running Windows CE. The authorized version of firmware will be stored in a documented place. What is required to allow future verification of the integrity of the stored, authorized version of the firmware file?

- ☐ Encrypt the file with an asymmetric key
- ☐ Create a message digest of the official file
- ☒ **Load the file onto write-once media**
- ☐ Save the file with restrictive, read-only, privileges

全82問中4問目

あるチームは、Windows CE上で動作する本番環境用HMIで使用するファームウェアのバージョンを確認しました。承認されたファームウェアのバージョンは、文書化された場所に保存されます。保存された承認済みファームウェアファイルの整合性を将来的に検証できるようにするには、何が必要ですか？

- ☐ 非対称鍵でファイルを暗号化する
- ☒ 公式ファイルのメッセージダイジェストを作成する
- ☒ ファイルを書き込み専用メディアにロードする
- ☐ ファイルを読み取り専用の制限付き権限で保存する

✖ あなたは間違っています

組み込み機器の製造に使用するファームウェアのバージョンを決定したら、チームはファイルのハッシュ値（メッセージダイジェスト、ワンウェイハッシュなど）を生成する必要があります。このハッシュ値は、同じハッシュアルゴリズムでファイルを実行し、出力が静的なままであることを確認することで、時間の経過とともに比較できます（ファイルが改ざんされていないことを示します）。

Question 5 of 82

Which type of ICS component uses the fastest polling rate?

- ☐ Regional SCADA
- ☐ Engineering workstation
- ☒ **Programmable logic controller**
- ☐ Site SCADA

全82問中5問目

ICSコンポーネントの中で、最も高速なポーリングレートを使用するのはどのタイプですか？

- ☐ 地域SCADA
- ☐ エンジニアリングワークステーション
- ☒ プログラマブルロジックコントローラ
- ☐ サイトSCADA

✓ その通りです

ポーリングレートは、さまざまな種類のICSコンポーネントを区別するのに役立ちます。地域SCADAは数秒から数分と最も長いポーリングレートを持ち、一方、コントローラやフィールドデバイスは1秒未満のタイミングで計測するため、最も短いポーリングレートになります。

Question 6 of 82

What does the stratum level of a time server indicate about that server?

- ☐ How vulnerable the time server is to denial-of-service attacks
- ☐ The level of reliability or direct quality of the time server
- ☐ The relative closeness of the server to a high quality time source
- ☒ **How vulnerable the server is to machine-in-the-middle attacks**

全82問中6問目

タイムサーバーの階層レベルは、そのサーバーについて何を示しているのでしょうか？

- ☐ タイムサーバーがサービス拒否攻撃に対してどれほど脆弱か
- ☐ タイムサーバーの信頼性または直接的な品質レベル
- ☒ サーバーが高品質の時刻ソースにどれだけ近いか
- ☒ サーバーが中間者攻撃に対してどの程度脆弱か

✕ あなたは間違っています

「ストラタム」という用語は、中央または高品質のタイムサーバーまたは基準タイムソースへの相対的な近さを示すために使用されます。このラベリングシステムは、0（より正確で最も近い）から15（精度が低く、最も遠い）までの尺度を使用します。ストラタムレベルは、信頼性や直接的な品質の尺度ではありません。ストラタム2のソースの中には、ストラタム1のソースよりも優先されるものがあります。NTP（タイム）サーバーは、パケットが暗号署名されていない限り、マシンインザミドル攻撃に対して脆弱です。NTPサーバーは、サービス拒否攻撃に対しても脆弱です。

Question 7 of 82

What is the function of a safety system (for example an SIS integrated into a plant's DCS)?

- ☐ Provide predictable and timely fail-safe shutdown of the process
- ☐ Sets standards for plant personnel to safeguard themselves from injury
- ☒ **Provide the control for hazardous materials in a process**
- ☐ Identify plant personnel locations during an emergency
- ☐ Open interlocks on command

全82問中7問目

安全システム（例えば、プラントのDCSに統合されたSIS）の機能は何ですか？

☒ プロセスの予測可能かつタイムリーなフェイルセーフシャットダウンを提供する

☐ 工場従業員が怪我をしないようにするための基準を定める。

☒ プロセスにおける危険物質の管理を提供する

☐ 緊急時に工場職員の所在を特定する

☐ 指示に応じてインターロックを開く

☒ あなたは間違っています

安全システムの機能は、事前に定義された安全状態／事象が発生した場合に、人員、環境、設備、および制御システムを保護するために、ICSアプリケーションとプロセスを予測可能かつタイムリーにフェイルセーフシャットダウンすることです。安全システムは専用の目的を果たし、この種の産業制御システムを必要とするプロセスにとって不可欠な機能です。安全システムは人員の位置を特定する役割を担うものではなく、人員の安全に関する管理基準を設定するためにも使用されません。安全システムはプロセスの主要な制御を行うものではなく、常に監視を行い、危険な状態が発生した場合に備えて待機しています。最後に、インターロックを開くのは、いずれのシステムにも属さない機能です。

Question 8 of 82

What communication method should an incident response team avoid using to discuss an active incident?

- ☒ **Walkie-talkie**
- ☐ Cell phone
- ☐ Voice over IP
- ☐ In person meeting

全82問中8問目

インシデント対応チームが、発生中のインシデントについて話し合う際に避けるべきコミュニケーション方法はどれですか？

☒ **トランシーバー** 6e15b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ 携帯電話

☒ **VoIP (Voice over IP)**

☐ 対面での会議

☒ **あなたは間違っています**

インシデント対応担当者は極度のプレッシャーにさらされる可能性があります。例えば、ネットワークシステム全体を感染させ、事実上使用不能にしてしまうワームを考えてみてください。これが、インシデント対応チームがVoIPに頼ってはならない理由の一つです。VoIPを導入している場合は、携帯電話、トランシーバー、またはその他のバックアップ通信手段の使用を検討してください。

Question 9 of 82

When in the recovery stage of an Incident Response, who determines when a system is put back into production?



System owner



Network manager



Security team



Incident handler

全82問中9問目

インシデント対応の復旧段階において、システムを本番環境に復帰させるタイミングは誰が決定するのですか？

☒ システムオーナー

☐ ネットワークマネージャー

☐ セキュリティチーム

☐ インシデントハンドラー

☒ その通りです

システムをいつ運用再開するかは、システム所有者が決定しなければなりません。担当者は助言や可能な限りのサポートを提供できますが、最終的にシステムをオンラインに戻すかどうかの決定権は、システム所有者または管理者にあります。

Question 10 of 82

What is a recommendation for setting up a secure ICS network architecture?

- ☐ Limit each Purdue level to having a single subnet in a non-SCADA environment
- ☒ **Deploy and manage virtualization technologies in Purdue level 3 separately from that of the enterprise**
- ☐ Place workstations having access to the Internet and corporate email at Purdue level 3
- ☐ Place writable aggregate plant historians in the ICS DMZ
- ☐ Put patch management servers for control systems in the ICS DMZ

全82問中10問目

安全なICSネットワークアーキテクチャを構築するための推奨事項は何ですか？

- ☐ 非SCADA環境では、各パーデューレベルに単一のサブネットのみを持たせるように制限する。
- ☒ **Purdueレベル3の仮想化技術を、エンタープライズレベルとは別に展開および管理する。**
- ☐ インターネットと社内メールにアクセスできるワークステーションをパデュー大学の3階に設置する。
- ☐ 書き込み可能な集合プラント履歴データをICS DMZに配置する
- ☐ 制御システムのパッチ管理サーバーをICS DMZに配置する

☒ その通りです

パッチサーバーをICS DMZに配置すると、パッチ適用のためDMZ ファイアウォールに多数の穴を開ける必要が生じます。このため、サーバーをレベル3内に配置することをお勧めします。Purdue レベル3で仮想化技術を使用する場合は、エンタープライズの仮想化技術とは別に展開および管理する必要があります。ネットワークはPurdue レベルごとに編成する必要がありますが、1つのPurdue レベルには複数のサブネットを含めることができます。インターネットおよび企業メールにアクセスできるシステムはレベル4より深く配置すべきではなく、下位レベルのスタッフがこのデータにアクセスする必要がある場合は、レベル4マシンを割り当てる必要があります。制御システムのパッチ管理サーバーはPurdue レベル3に配置する必要があります。ICS DMZに配置すると、ファイアウォールルールが安全でない可能性があります。集約プラント履歴はPurdue レベル3に配置し、必要に応じてICS DMZ内の読み取り専用履歴に複製する必要があります。

Question 11 of 82

Which of the following Windows event logs would an analyst review to research Windows Service start, stop, and/or failure messages?

- ☒ **System**
6e137b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☐ Security
- ☐ Application
- ☐ Administrative

全82問中11問目

アナリストがWindowsサービスの開始、停止、および/または失敗メッセージを調査するために確認するWindowsイベントログは次のうちどれですか？

☒ システム
6e13b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ 安全

☐ 応用

☐ 管理

☒ その通りです

システムログには、Windowsサービスに関する問題が記録されます。管理者が最初に確認すべき論理的な場所はそこでしょう。

Question 12 of 82

What is an example of deterrence as a physical security defense?



Bright lighting



Hidden cameras



Physical walk-down



Audible alarms

全82問中12問目

物理的な安全保障対策としての抑止力の例を挙げてください。

6e13b03-99b1-4dd8-bedd-29c33c5a25ba (14232740)

☒ 明るい照明

☐ 隠しカメラ

☐ 物理的な徒歩移動

☐ 可聴アラーム

☒ その通りです

物理的なセキュリティ対策には、抑止、遅延、検知、対応が含まれます。抑止とは、攻撃者が攻撃を試みる可能性を低減するあらゆるセキュリティ機能を指します。例としては、有刺鉄線付きの高いフェンス、目に見えるカメラ、明るい照明、目立つ警備員などが挙げられます。侵入を施設職員に知らせる可聴アラームは、検知の一例です。完全に効果的な抑止策であれば、可聴アラームの使用は不要になります。物理的な巡回点検とは、経験豊富な現場職員が、何か紛失または異常がないかを確認するために行う検査です。

Question 13 of 82

Which zone should be used to centralize data and services so they can be shared between zone boundaries?

- ☒ **Enforcement zone**
- ☐ Demilitarized zone
- ☐ Business zone
- ☐ Safety zone

全82問中13問目

データとサービスをゾーン境界を越えて共有できるように、それらを一元化するにはどのゾーンを使用すべきでしょうか？

☒ 執行区域
6e137b03-99b7-4bd8-bedd-29c33c5a25ba (14232740)

☒ 非武装地帯

☐ ビジネスゾーン

☐ 安全区

☒ あなたは間違っています

DMZは、機能ごとに異なる一連のゾーンを提供し、ゾーン間でサービスやデータを共有できるようにする。

Question 14 of 82

A firm reviews the results of a disaster recovery test where customers were unaware of an alternative support website. Which of the following does the firm need to address in the BCP/DR process?

- ☐ Lack of prioritization
- ☐ Lack of security controls
- ☐ Lack of plan ownership
- ☒ **Lack of communication**

全82問中14問目

ある企業が、顧客が代替サポートウェブサイトの存在を知らなかったという災害復旧テストの結果を検証しています。企業は、BCP/DRプロセスにおいて、次のうちどれに対処する必要がありますか？

- ☐ 優先順位付けの欠如
- ☐ セキュリティ管理の欠如
- ☐ 計画に対する所有権の欠如
- ☒ コミュニケーション不足

✓ その通りです

コミュニケーション不足とは、組織のあらゆる関係者（従業員、契約社員、ベンダー、ビジネスパートナー、顧客、株主など）との明確かつ正確なコミュニケーションの必要性を考慮していないことを意味します。これは広報計画にも当てはまります。

Question 15 of 82

What will the following Powershell script accomplish?

```
Get-Service | Select-Object Name, Status | Export-CSV c:\list.csv
```

- ☐ Generate a list of object names and statuses the operator can choose from and export those chosen to a CSV file
- ☒ **Create a CSV file containing the name and status of every system service**
- ☐ Perform an HTTP GET on all entries identified in the supplied CSV file
- ☐ Prompt for an object name, and create a CSV file containing its name and status

以下のPowerShellスクリプトは何を実行しますか？

```
Get-Service | Select-Object Name, Status | Export-CSV c:\list.csv
```

- ☐ オペレーターが選択できるオブジェクト名とステータスのリストを生成し、選択されたものをCSVファイルにエクスポートします。
- ☒ **すべてのシステムサービスの名前とステータスを含むCSVファイルを作成します。**
- ☐ 提供されたCSVファイルで識別されたすべてのエントリに対してHTTP GETを実行します。
- ☐ オブジェクト名の入力を求め、その名前とステータスを含むCSVファイルを作成します。

☒ **その通りです**

PowerShellのGet-Serviceコマンドは、システムにインストールされているすべてのサービスを識別します。その出力はSelect-Objectコマンドにパイプされ、指定されたパラメーターに従って元の出力が絞り込まれます。ここでは、Select-Objectは各サービスの名前とそのステータスのみを出力します。その出力はExport-CSVコマンドにパイプされ、PowerShellからの出力がフォーマットされて指定されたCSVファイルにエクスポートされます。

Question 16 of 82

Which of the following message security properties does a digital signature provide in the context of public-key cryptography?

- ☐ Integrity and availability
- ☒ **Confidentiality and integrity**
- ☐ Integrity and non-repudiation
- ☐ Non-repudiation and confidentiality

全82問中16問目

公開鍵暗号方式において、デジタル署名は以下のメッセージセキュリティ特性のうちどれを提供しますか？

- ☐ 誠実さと可用性
- ☒ 機密保持と誠実性
- ☒ 誠実さと否認の禁止
- ☐ 否認防止および機密保持

☒ あなたは間違っています

公開鍵暗号に基づくデジタル署名は、メッセージが改ざんされていないことを証明し、送信者／作成者の身元を確認するため、完全性と否認防止の両方を保証します。署名に使用された公開鍵に対応する秘密鍵を保有する者のみが、このメッセージを作成できたはずですが、ただし、デジタル署名はメッセージの機密性を保証するものではありません。暗号化せずに送信された平文メッセージに付加することも可能です。また、一連のメッセージに累積署名を使用しない限り、メッセージが送信中に検出されずに失われる可能性があるため、可用性も保証されません。

Question 17 of 82

Which device can be used to prevent a MODBUS write command from being executed on a PLC where only read commands are expected?

- ☐ Packet-filtering firewall
- ☐ Application-layer firewall
- ☒ **Data diode**
- ☐ Network intrusion detection sensor

全82問中17問目

読み取りコマンドのみが想定されるPLCで、MODBUS書き込みコマンドが実行されないようにするには、どのデバイスを使用すればよいですか？

- ☐ パケットフィルタリングファイアウォール
- ☒ アプリケーション層ファイアウォール
- ☒ データダイオード
- ☐ ネットワーク侵入検知センサー

× あなたは間違っています

アプリケーションファイアウォール（「次世代ファイアウォール」とも呼ばれる）は、アプリケーションレベルでプロトコルを解釈し、パケットの値と内容に基づいて判断を下すことができます。アプリケーションファイアウォールのルールは、定義された範囲外の値を含むトラフィックを破棄するように設定できます。パケットフィルタリングファイアウォールは、送信元および宛先IPアドレスやポートなど、パケットのネットワーク層およびトランスポート層ヘッダーに含まれる情報に基づいて判断を下します。

Question 18 of 82

If an asset has an SLE of \$36,000 and an ALE of \$144,000 what is the applicable ARO?

- ☐ \$108,000
- ☐ 1/4
- ☐ 4
- ☒ \$180,000

全82問中18問目

資産のSLEが36,000ドル、ALEが144,000ドルの場合、適用されるAROはいくらですか？

- ☐ 10万8000ドル
- ☐ 1/4
- ☒ 4
- ☐ 18万ドル

✖ あなたは間違っています

$$\text{ALE} = \text{SLE} * \text{ARO}$$

$$\$144,000 = \$36,000 * \text{ARO}$$

$$\text{ARO} = \$144,000 / \$36,000$$

$$\text{ARO} = 4$$

Question 19 of 82

What is the suggested action to protect a system running a Microsoft operating system that has reached the end of extended support?

- ☒ **Move to the Enterprise edition of the OS**
- ☐ Purchase and apply security hotfixes as they are released
- ☐ Logically isolate the system
- ☐ Provide automated patch updates

全82問中19問目

延長サポートが終了したMicrosoftオペレーティングシステムを実行しているシステムを保護するために推奨される対策は何ですか？

- ☒ **OSのエンタープライズ版に移行する**
- ☐ セキュリティ修正プログラムがリリースされたら、購入して適用してください。
- ☒ **システムを論理的に分離する**
- ☐ 自動パッチアップデートを提供する

× あなたは間違っています

OSの延長サポート期間が終了し、代替OSが利用できない場合、マイクロソフトはOSを隔離することを推奨しています。延長サポート期間が終了したOSでは、その他のオプションはすべて利用できません。

Question 20 of 82

Which of the following vulnerabilities could be tested for by using the string below?

```
<script>alert(String.fromCharCode(88,83,83))</script>
```

☐ SQL injection

☐ Cross Site Request Forgery

☒ **Cross Site Scripting**

☐ Control Signal Spoofing

全82問中20問目

以下の文字列を使用することで、次のうちの脆弱性をテストできるでしょうか？

```
<script>alert(String.fromCharCode(88,83,83))</script>
```

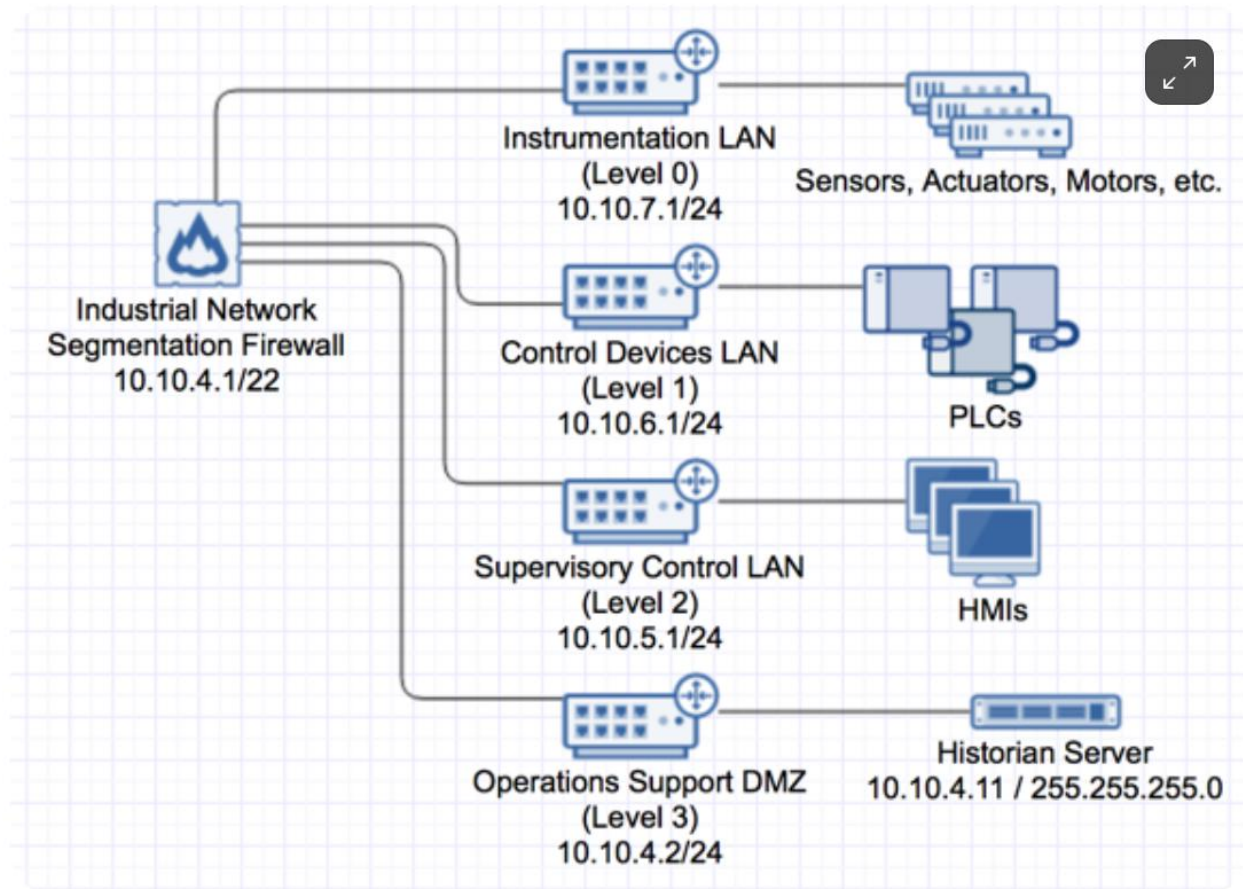
- ☐ SQLインジェクション
- ☐ クロスサイトリクエストフォージェリ
- ☒ **クロスサイトスクリプティング**
- ☐ 制御信号の偽装

☒ その通りです

このスクリプトは、Webページがクロスサイトスクリプティングの脆弱性を持っているかどうかを判断するための、信頼性の高いシンプルなテストです。脆弱性がある場合、処理がこのスクリプトに到達した時点でページは警告を表示します。このスクリプトは、上記に挙げたその他の脆弱性についてはテストしません。

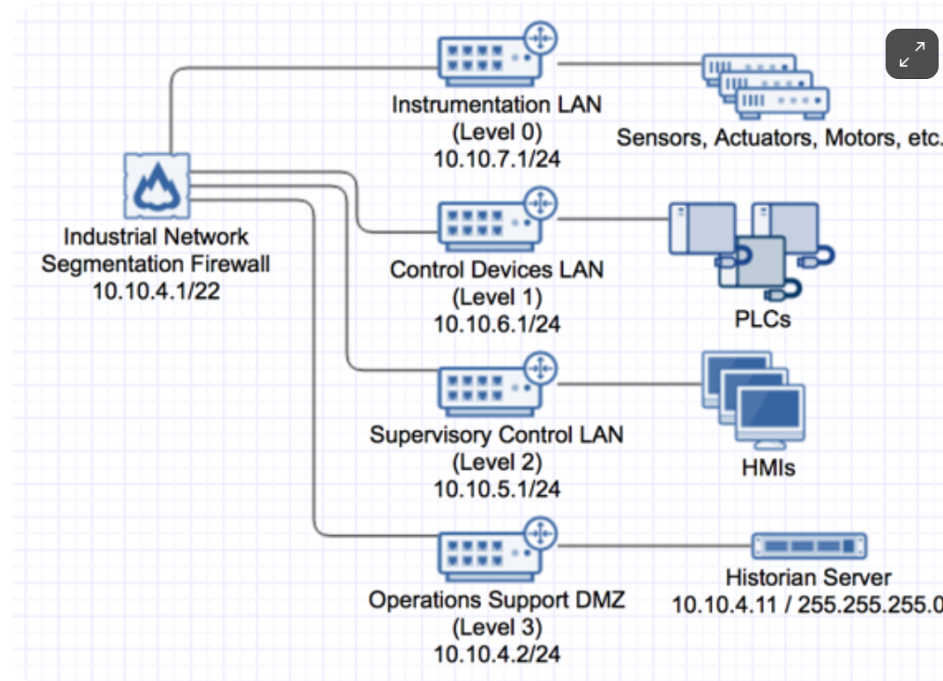
Question 21 of 82

Using the network diagram for context, which of the following source IP addresses would be blocked from connecting to the Instrumentation LAN by an anti-spoofing rule on the firewall?



- ☐ 10.10.6.24
- ☐ 10.10.5.77
- ☐ 10.10.7.187
- ☒ 10.10.4.3

ネットワーク図を参考に、ファイアウォールのなりすまし防止ルールによって計測LANへの接続がブロックされる送信元IPアドレスは次のうちどれですか？



- ☐ 10.10.6.24
- ☐ 10.10.5.77
- ☒ 10.10.7.187
- ☒ 10.10.4.3

❌ あなたは間違っています

保護対象ネットワークのアドレス空間内の送信元アドレスを含む受信パケットはすべて破棄する必要があります。これらのパケットが攻撃者によるアドレスのなりすましによるものか、ルーティングの問題によるものかにかかわらず、受信を許可してはなりません。10.10.4.0/24、10.10.5.0/24、および10.10.6.0/24ネットワークをブロックする理由は他にも考えられますが、なりすましは理由になりません。

Question 22 of 82

The head of the Ackme IT department sent a directive stating that all company communication must use TLS in order to prevent third parties from modifying data without Ackme's knowledge. Which part of the C-I-A model is the head of IT concerned with?

- ☐ Availability
- ☐ Confidentiality
- ☒ **Integrity**
- ☐ Encryption

全82問中22問目

Ackme社のIT部門責任者は、第三者がAckme社の許可なくデータを改ざんすることを防ぐため、すべての社内通信にTLSを使用するよう指示を出しました。IT部門責任者はCIAモデルのどの部分に関心を持っているのでしょうか？

- ☐ 可用性
- ☐ 機密保持
- ☒ 誠実さ
- ☐ 暗号化

☒ その通りです

データの完全性とは、データが不正に改ざんされることがないという保証によって定義される。

Question 23 of 82

Which of the following IEEE standards specifies a framework for network authentication?

- ☐ 802.11ad
- ☒ **802.3**
- ☐ 802.11ac
- ☐ 802.1x

全82問中23問目

次のIEEE規格のうち、ネットワーク認証のフレームワークを規定しているのはどれですか？

- ☐ 802.11ad
- ☒ **802.3**
- ☐ 802.11ac
- ☒ **802.1x**

✖ あなたは間違っています

認証はIEEE 802.1xワーキンググループの任務であり、彼らはネットワーク認証のためのフレームワークを設計した。この認証フレームワークは、拡張認証プロトコル（EAP）と呼ばれる複数の異なる認証プロトコルに対応している。

Question 24 of 82

When a HMI panel displays an alarm from a device's tamper sensor, which type of physical security control does it indicate?

- ☐ Response
- ☐ Prevention
- ☐ Deterrence
- ☒ **Detection**

全82問中24問目

HMIパネルにデバイスの改ざんセンサーからのアラームが表示された場合、それはどのようなタイプの物理的セキュリティ制御を示しているのでしょうか？

- ☐ 応答
- ☐ 防止
- ☐ 抑止力
- ☒ 検出

☒ その通りです

改ざん検知センサーは、セキュリティ侵害が発生した可能性を検知し、攻撃者を特定できます。物理的な抑止力は攻撃の試みの可能性を低減し、遅延機能は攻撃者の行動を遅らせます。物理的な認証レベルは、許可された担当者のみがエリアにアクセスできるようにする機能であり、対応機能は物理的な防御の最終段階であり、攻撃の結果として担当者と手順を発動します。

Question 25 of 82

If a single loss expectancy is equal to \$30,000 with an exposure factor of 30%, what is the value of the asset?

- ☐ \$1,000
- ☐ \$30,000
- ☐ \$100,000
- ☒ **\$10,000**

全82問中25問目

単一損失期待値が3万ドルで、エクスポージャー係数が30%の場合、資産の価値はいくらですか？

- ☐ 1,000ドル
- ☐ 3万ドル
- ☒ 10万ドル
- ☐ 1万ドル

✕ あなたは間違っています

$$SLE = AV * EF$$

$$\$30,000 = AV * 30\%$$

$$AV = \$30,000 / 30\%$$

$$AV = \$100,000$$

Question 26 of 82

Which of the following is part of the Protect function of the NIST CSF (cybersecurity framework)?

- ☐ Containing an event and eradicating it from the network
- ☐ Monitoring the network for malicious activity
- ☐ Providing awareness training for organizational personnel and partners
- ☒ **Establishing security policies and personnel responsibilities**

NIST CSF（サイバーセキュリティフレームワーク）の保護機能に含まれるものはどれですか？

- ☐ イベントを封じ込め、ネットワークから排除する
- ☐ 悪意のある活動がないかネットワークを監視する
- ☒ 組織の職員およびパートナー向けに意識向上トレーニングを提供する
- ☒ セキュリティポリシーと担当者の責任を確立する

✖ あなたは間違っています

組織の従業員およびパートナーに対し、サイバーセキュリティ意識向上トレーニングを提供することは、保護機能の一部です。セキュリティポリシーの策定、従業員の役割と責任の明確化は、識別機能に該当します。検出機能の目的の一つは、ネットワーク上の悪意のある活動を監視することです。事象の拡散を防ぎ、ネットワークから排除する緩和策は、対応機能の一部です。

NIST CSR Protect (PR) 機能より:

意識向上とトレーニング (PR.AT) : 組織の職員およびパートナーは、サイバーセキュリティ



セキュリティ ポリシーと担当者の責任を確立することは、ID 機能 (ID)、**ID.GV**の一部です。

ネットワークの監視は、検出 (DE) 機能、DE.CMの一部です。

封じ込めと根絶は、回復 (RC) 機能、**RC.RP**の一部です。

Question 27 of 82

Which factors are compared in a security Cost Benefit Analysis?

- ☐ Cost of a business process and value produced by that process
- ☐ Reputation cost and value of the protected asset
- ☒ **Cost of controls and value of the reduced risk**
- ☐ Cost of breach and value of the lost revenue flow

全82問中27問目

セキュリティの費用対効果分析では、どのような要素が比較されますか？

- ☐ ビジネスプロセスのコストと、そのプロセスによって生み出される価値
- ☐ 評判コストと保護対象資産の価値
- ☒ **管理コストとリスク低減の価値**
- ☐ 侵害コストと失われた収益フローの価値

☒ その通りです

セキュリティ対策を実施する際、費用便益分析では、セキュリティ対策のコストと、それによって得られるリスク軽減効果を比較します。評判コストは、セキュリティインシデントで発生するものであり、企業の資産価値とは無関係であるため、費用便益分析の対象にはなりません。収益損失額は、侵害コストに含まれる要素であり、どちらも損失（コスト）です。ICSのコストと、ICSが生み出す価値は、ICSへの初期投資を裏付ける費用便益分析を構成します。

Question 28 of 82

Which protocol makes use of CSMA/CD so that multiple devices can communicate on the same Layer 1 medium?

- ☐ Internet Protocol (IP)
- ☐ Modbus
- ☒ **Ethernet**
- ☐ Profibus

全82問中28問目

複数のデバイスが同じレイヤ1媒体上で通信できるように、CSMA/CDを利用するプロトコルはどれですか？

- ☐ インターネットプロトコル (IP)
- ☐ Modbus
- ☒ イーサネット
- ☐ プロフィバス

✓ その通りです

CSMA/CDは、イーサネットプロトコルにおいてネットワーク上の衝突を検出し、再送信の必要性を示すために使用されます。これにより、同じレイヤ1媒体を使用して複数の通信が可能になります。

Question 29 of 82

Which type of device is the following configuration setting from?

```
permit tcp host 192.168.3.66 host 10.10.8.71 eq 22
```

- ☐ SIEM
- ☒ **Network firewall**
- ☐ NIDS
- ☐ Application firewall

全82問中29問目

以下の設定は、どのタイプのデバイスのものですか？

```
permit tcp host 192.168.3.66 host 10.10.8.71 eq 22
```

- ☐ SIEM
- ☒ ネットワークファイアウォール
- ☐ NIDS
- ☐ アプリケーションファイアウォール

☒ その通りです

ネットワークファイアウォールは、IPアドレスとポートに基づいて許可/ブロックの判断を行います。

Question 30 of 82

What is being determined when multiplying an asset value to the exposure factor (EF) percentage?

- ☐ Annualized rate occurrence
- ☐ Single loss expectancy
- ☒ **Annualized loss expectancy**
- ☐ NERC CIP fine

全82問中30問目

資産価値にエクスポージャー係数（EF）のパーセンテージを乗じることで、何が決定されるのでしょうか？

- ☐ 年間発生率
- ☒ 単一損失期待値
- ☒ 年間損失期待値
- ☐ NERC CIP罰金

× あなたは間違っています

SLEは、単一の事象に割り当てられる金額です。つまり、単一の事象によって組織が被る損失額です。エクスポージャーファクター（EF）は、脅威事象が資産に及ぼす損失の割合です。EFは、資産の損失率0～100%で表されます。その計算式は次のとおりです。単一損失期待値（SLE）＝資産価値×損失率（EF）

Question 31 of 82

Which of the following is a benefit of deploying a centralized SIEM solution?

- ☒ **Events from different systems can be correlated to monitor for trends and anomalies.**
- ☐ Archived sensor and safety process data can be stored and accessed long term for performance reporting.
- ☐ Vulnerable systems can be updated to current configuration and patch management standards.
- ☐ Known attack traffic can be blocked before it reaches vulnerable hosts on the internal network.

全82問中31問目

集中型SIEMソリューションを導入するメリットは次のうちどれですか？

- ☒ 異なるシステムからのイベントを相関させることで、傾向や異常を監視することができる。
- ☐ アーカイブされたセンサーデータと安全プロセスデータは、パフォーマンスレポート作成のために長期保存およびアクセスが可能です。
- ☐ 脆弱なシステムは、最新の構成およびパッチ管理基準に合わせて更新することができます。
- ☐ 既知の攻撃トラフィックは、内部ネットワーク上の脆弱なホストに到達する前にブロックすることができる。

✔ その通りです

セキュリティ情報およびイベント管理（SIEM）製品は、一部の組織で、侵入の試みを検出するために、IDSおよびIPSのログ、ならびに他のコンピュータシステム、アプリケーション、インフラストラクチャ機器、その他のハードウェアおよびソフトウェアの監査ログからのイベントを監視、分析、相関付けるために使用されています。

SIEMは、センサーや安全装置などのデータヒストリアンのようなパフォーマンス指標を提供しません。悪意のあるトラフィックをブロックするには、SIEMではなくIPSやファイアウォールを使用します。また、SIEMはネットワークホストの構成管理やパッチ管理も提供しません。

Question 32 of 82

Which of the following protocols can be used to manage and audit user account logins across a large network of embedded devices?

☐ Modbus

☐ WSUS

☐ DNP3

☒ **RADIUS**

全82問中32問目

以下のプロトコルのうち、大規模な組み込みデバイスネットワーク全体でユーザーアカウントのログインを管理および監査するために使用できるものはどれですか？

- ☐ Modbus
- ☐ WSUS
- ☐ DNP3
- ☒ 半径

✓ その通りです

RADIUSプロトコルは、ネットワーク全体にわたる集中型認証、認可、アカウントティング（AAA）をサポートするように特別に設計されており、ほとんどの組み込みデバイスは、アカウントとパスワードをローカルで管理する機能に加えて、RADIUSもサポートしています。WSUSはWindows Server Update Servicesの略で、サーバーやワークステーションなどのMicrosoft Windowsエンドポイントにソフトウェアパッチやアップデートを配布するために使用されます。DNP3とModbusはどちらもSCADA通信に使用され、アカウント管理機能はありません。

Question 33 of 82

Which layer in the OSI model is responsible for handling the sequencing of data segments?

- ☐ Transport
- ☐ Data Link
- ☒ **Network**
- ☐ Presentation

OSIモデルのどの層がデータセグメントの順序付けを担当していますか？

☒ 輸送
6e137b03-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ データリンク

☒ ネットワーク

☐ プレゼンテーション

☒ あなたは間違っています

トランスポート層は、ネットワーク層からのパケットとやり取りし、パケットをシーケンス化して送信の準備を行います。TCPの場合、エンドツーエンドの信頼性の高い接続を保証し、送信のためにパケットをセグメントにシーケンス化する処理も行います（UDPは信頼性の高い送信を保証せず、パケットはセグメントではなくデータグラムとして送信されます）。ネットワーク層は、複数のネットワークセグメントの接続を処理し、異なるネットワークセグメント上のシステムがどのように互いを検出して通信するかを記述します。データリンク層は、ネットワークの物理的な部分（ケーブルと電気信号）と抽象的な部分（パケットとデータストリーム）を接続します。プレゼンテーション層は、接続の一方の側から送信されたデータが、もう一方の側にとって有用な形式で受信されるようにします。

Question 34 of 82

Which layer of the OSI model does UDP belong to?

- ☐ Layer 2 - Data Link
- ☒ **Layer 4 - Transport**
- ☐ Layer 5 - Session
- ☐ Layer 3 - Network

全82問中34問目

UDPはOSIモデルのどの層に属しますか？

- ☐ レイヤー2 - データリンク
- ☒ レイヤー4 - トランスポート
- ☐ レイヤー5 - セッション
- ☐ レイヤー3 - ネットワーク

✓ その通りです

TCPと同様に、UDPはトランスポート層で動作します。IPはネットワーク層で動作し、イーサネットなどのプロトコルはデータリンク層で動作します。NetBIOSやRPCなどのプロトコルはセッション層で定義されています。

Question 35 of 82

What is described below?

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
If the velocity is 15 kn or less, the throttle is set to 100%.
If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
If the velocity is between 20 kn and 25 kn the throttle is set to 50%.
If the velocity is between 25 kn and 30 kn the throttle is set to 25%.



Ladder logic

- ☐ Instruction list
- ☐ Sequential function block
- ☐ PID loop
- ☐ Fuzzy logic

全82問中35問目

以下に説明されている内容は何ですか？

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.

If the velocity is 15 kn or less, the throttle is set to 100%.

If the velocity is between 15 kn and 20 kn the throttle is set to 75%.

If the velocity is between 20 kn and 25 kn the throttle is set to 50%

If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- 6e10b05-99b1-4bd8-bedd-29c33c5a25ba (14232740)
- ☒ ラダーロジック
 - ☐ 手順一覧
 - ☐ シーケンシャルファンクションブロック
 - ☐ PIDループ
 - ☒ ファジーロジック

× あなたは間違っています

ファジー論理は「真偽の度合い」に関係します。USVが30ノットを超えて移動している場合、それは速すぎる速度で移動していますが、論理式で単にyesまたはno;1または0を使用した場合、「どれくらい」速すぎるかはわかりません。31ノットでの移動も速すぎますし、70ノットでの移動も速すぎますが、これらの状態それぞれに対して異なる対応が必要になる場合があります。この論理式は、人が読みやすく、システムが何をすべきかを簡単に識別できます。これらの論理式は、数学的評価のためにファジー論理に変換されます。

ラダーロジックと命令リストは、プログラミング言語の一種である。

Question 36 of 82

Which of the following is a vulnerability specific to an authentication bypass attack on a web application?

- ☐ Accepting unencrypted connections over TCP 80
- ☐ Accommodating outdated browser connections
- ☒ **Allowing weak session management**
- ☐ Authenticating with alphabetical passwords

次のうち、Webアプリケーションに対する認証バイパス攻撃に特有の脆弱性はどれですか？

- ☐ TCPポート80経由で暗号化されていない接続を受け入れる
- ☐ 古いブラウザ接続への対応
- ☒ **脆弱なセッション管理を許可する**
- ☐ 英字パスワードによる認証

✔ その通りです

ウェブアプリケーションでは、通常、セッショントークンを含むセキュアなクッキーをユーザーに提供します。ユーザーのブラウザは、確立された認証セッションを示すために、リクエストごとにそのクッキーをサーバーに送信します。脆弱なセッション管理とは、クッキーが安全でない、または攻撃者がその内容を推測できる場合、あるいはウェブアプリケーションの実装でセッション管理が全く使用されていない場合を指します。脆弱なセッション管理の脆弱性が存在する場合、攻撃者はウェブアプリケーションの認証をより容易に回避できます。認証バイパスは、パスワードクラッキングや推測/ファジングとは関係ありません。これは、ユーザーを適切に認証していないウェブアプリケーションのリクエストを悪用するものです。

Question 37 of 82

An engineer is downloading a patch for their HMIs; what practice can verify the integrity of the downloaded file?

- ☐ Scanning the file with an anti-virus tool
- ☐ Authenticating to the vendor website prior to downloading the file
- ☐ Checking the message digest of the downloaded file
- ☒ **Restricting downloads to sites that use SSL**

全82問中37問目

エンジニアがHMI用のパッチをダウンロードしているとき、ダウンロードしたファイルの整合性を検証するにはどのような方法がありますか？

- ☐ ウイルス対策ツールでファイルをスキャンする
- ☐ ファイルをダウンロードする前に、ベンダーのウェブサイトで認証を行う
- ☒ ダウンロードしたファイルのメッセージダイジェストを確認する
- ☒ SSLを使用しているサイトからのダウンロードを制限する

× あなたは間違っています

ファイルの完全性、つまり改ざんされていないことを検証するには、一方向ハッシュまたは証明書キーを使用するのが効果的です。ベンダーはハッシュ出力（チェックサム、メッセージダイジェストなど）を提供し、受信者はファイルをダウンロードした後、ベンダーから提供されたチェックサムとローカルでチェックサムを検証できます。アンチウイルスソフトでファイルをスキャンすることは良い方法ですが、ファイルの完全性を保証するものではなく、アンチウイルスソフトの署名データベースにある「悪意のある」情報とファイルが一致するかどうかを確認するものです。ダウンロードをSSL/TLS（HTTPS）のみに制限したり、ベンダーのWebサイトで認証したりしても、ファイルの完全性は検証されません。

Question 38 of 82

Which of the following is the term that describes the process condition where a hazardous safety, health, and environmental event cannot occur?



Ready state



Recovery mode



Fail state



Safe state



Restore mode

危険な安全、健康、環境事象が発生しないプロセス状態を表す用語は、次のうちどれですか？

☒ 準備完了状態

☐ リカバリーモード

☐ 障害状態

☒ 安全な状態

☐ 復元モード

☒ あなたは間違っています

安全計装システム（SIS）は、特に重要なプロセスシステムで使用する、設計されたハードウェアとソフトウェアの制御システムから構成されます。重要なプロセスシステムとは、稼働中に運用上の問題が発生した場合、安全、健康、環境（SH&E）への悪影響を回避するために、システムを安全な状態にする必要が生じる可能性があるシステムを指します。

安全状態とは、プロセスが稼働中か停止中かを問わず、危険な安全衛生環境事象が発生しないようなプロセス状態のことです。安全状態は、適切な時期に、すなわち「プロセス安全時間」内に達成されなければなりません。

Question 39 of 82

Which of the following describes the process of modulation?

- ☐ Changing of carrier signal information for transmission
- ☐ Broadcasting of RF signals through the airwaves
- ☒ **Modification of digital data to become RF data**
- ☐ Processing of carrier signals received by RF antennas

全82問中39問目

次のうち、変調のプロセスを説明しているのはどれですか？

- ☒ **送信のための搬送波信号情報の変更**
- ☐ 電波を介したRF信号の放送
- ☒ **デジタルデータをRFデータに変換する**
- ☐ RFアンテナで受信した搬送波信号の処理

× あなたは間違っています

変調とは、搬送波と呼ばれる周期的な波形の1つまたは複数の特性を、通常は送信する情報を含む変調信号と呼ばれる別の信号で変化させるプロセスです。変調には主に2つの種類があります。1つ目は振幅変調（AM）で、信号の電力を変化させてデータを符号化します。2つ目は周波数変調で、搬送波の周波数をわずかに変化させてデータを表します。

Question 40 of 82

Which level is the most granular for applying GPO policies in Active Directory?

- ☐ Workgroup
- ☒ **Domain**
- ☐ Forest
- ☐ Organizational Unit

全82問中40問目

Active DirectoryでGPOポリシーを適用する際に、最も詳細なレベルはどれですか？

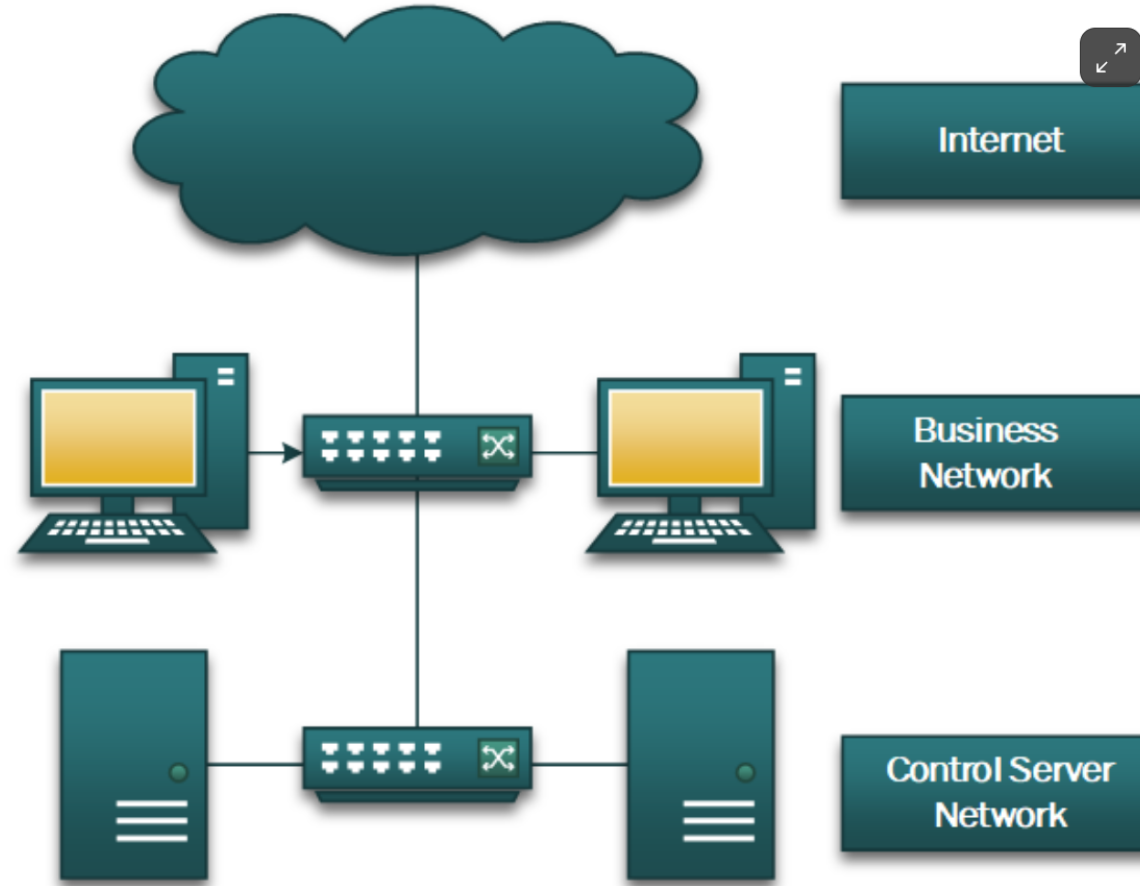
- ☐ ワーキンググループ
- ☒ ドメイン
- ☐ 森
- ☒ 組織単位

× あなたは間違っています

ベストプラクティスとしては、ドメインレベルではなく組織単位レベルでGPOを管理するのが一般的です。これは、すべてのシステムに同じGPOを適用できるドメインはごく少数であるため、OUの方がドメインよりも粒度が細かいからです。フォレストは、AD構造の中で最も粒度の小さい単位です。ワークグループはADとGPOをサポートしていません。GPOをユーザーアカウントに直接適用することはできません。

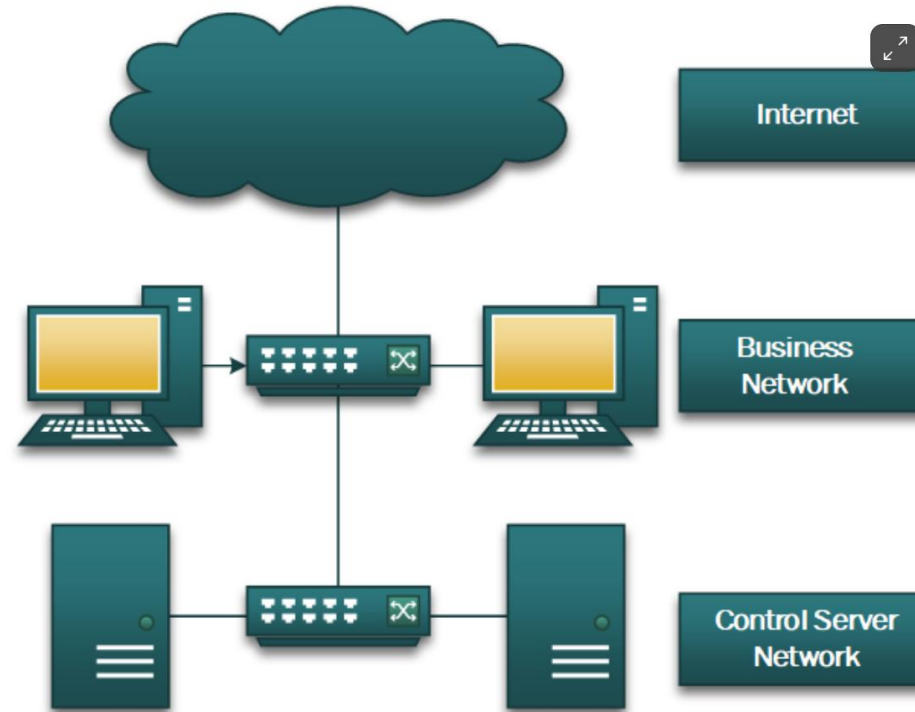
Question 41 of 82

Based on the network shown in the diagram, at minimum how many firewalls should be installed?



- ☐ 1
- ☐ 3
- ☐ 5
- ☐ 4
- ☒ 2

図に示されたネットワーク構成に基づくと、最低限いくつのファイアウォールを設置する必要がありますか？



- ☐ 1
6e11b03-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☐ 3
- ☐ 5
- ☐ 4
- ☒ 2

✔ その通りです

各適用ゾーン間にはファイアウォールを設置し、不要なトラフィックや望ましくないトラフィックがゾーンを通過するのを防ぐ必要があります。図に示すように、これを実現するには、インターネットとビジネスネットワークの間に1つ目のファイアウォールを設置し、ビジネスネットワークと制御サーバーネットワークの間にもう1つのファイアウォールを設置する必要があります。

Question 42 of 82

Which communication method offers the longest range for connecting remote sites to a central control center?

- ☐ 802.11n
- ☐ Microwave
- ☒ **VSAT**
- ☐ CDMA

全82問中42問目

遠隔地と中央管制センターを接続する際に、最も長距離の通信が可能なのはどの通信方式ですか？

- ☐ 802.11n
- ☐ 電子レンジ
- ☒ **VSAT**
- ☐ CDMA

✓ その通りです

海上石油プラットフォームのような遠隔地では、機器を企業の中央制御センターに接続する唯一の方法として、衛星（VSAT、BGANなど）によるアップリンクが選択肢となる場合がある。

Question 43 of 82

Which asset would an ICS database rely on to perform third-party data translation?

- ☐ OPC server
- ☐ PI server
- ☒ **Intelligent Electronic Device (IED)**
- ☐ HMI workstation

全82問中43問目

ICSデータベースは、サードパーティデータの変換を実行するために、どの資産に依存するのでしょうか？

- ☒ **OPCサーバー**
- ☐ PIサーバー
- ☒ **インテリジェント電子機器（IED）**
- ☐ HMIワークステーション

✕ あなたは間違っています

OPCサーバーは、ヒストリアンなどのサービス向けにサードパーティのデータ変換機能を提供することがよくあります。これにより、共通の通信プロトコルを共有していないアセット間でも通信が可能になります。PIシステムのようなヒストリアンの場合、OPCサーバーは、異なる形式で保存されたデータをPIシステムに供給し、データの表示や操作を可能にするために使用されます。

Question 44 of 82

Which of the following is most effective in ensuring one way data communication from the control system network to a data historian?

- ☐ Data diodes
- ☒ **Data concentrator**
- ☐ Switch port security
- ☐ Routers

全82問中44問目

制御システムネットワークからデータヒストリアンへの一方向のデータ通信を確実にするために、次のうちどれが最も効果的ですか？

- ☒ **データダイオード**
- ☒ **データコンセントレータ**
- ☐ スイッチポートのセキュリティ
- ☐ ルーター

☒ **あなたは間違っています**

データダイオードは、一方向のデータ通信経路を提供します。データコンセントレータ、ルータ、およびスイッチポートのセキュリティはすべて、それぞれがサポートする通信経路におけるトラフィックの送受信をサポートします。

Question 45 of 82

How are Microsoft security templates stored?

- ☐ Proprietary format based on JSON
- ☐ Base64 encoded
- ☐ Plaintext file
- ☒ **XML file**

全82問中45問目

Microsoftのセキュリティテンプレートはどのように保存されますか？

- ☐ JSONに基づいた独自のフォーマット
- ☐ Base64エンコード
- ☒ プレーンテキストファイル
- ☒ XMLファイル

✖ あなたは間違っています

Microsoft セキュリティ テンプレートは、数百ものセキュリティ設定を保存できるプレーンテキスト構成ファイルです。メモ帳などのテキストエディタで手動で編集することもできますが、MMC スナップインの「セキュリティ テンプレート」を使用する方がはるかに安全で簡単です。

Question 46 of 82

Jeff has just installed a new Windows based workstation into the domain on his company's DCS network. A screen saver pops up every five minutes and Jeff does not want the screensaver active on this workstation. Jeff calls up the local policy on the workstation and sees that there is an active screen saver policy. Jeff tries to update the policy, but the button is greyed out and won't allow updates. What is most likely preventing Jeff from disabling the screen saver on this workstation?

- ☐ Jeff's account is in the local administrator's group, but not included in the local policy group.
- ☐ The DCS vendor has applied custom program code to prevent unauthorized tampering with local policy.
- ☒ **There is a domain based policy being applied to the workstation that overrides the local security policy.**
- ☐ No policies are being applied because the workstation has the wrong refresh settings applied.

ジェフは、会社のDCSネットワーク上のドメインに、Windowsベースの新しいワークステーションをインストールしました。5分ごとにスクリーンセーバーがポップアップ表示されるのですが、ジェフはこのワークステーションでスクリーンセーバーを有効にたくありません。ワークステーションのローカルポリシーを確認すると、スクリーンセーバーポリシーが有効になっていることがわかりました。ジェフはポリシーを更新しようとしませんが、ボタンがグレー表示になっていて更新できません。ジェフがこのワークステーションでスクリーンセーバーを無効にできない原因として最も考えられるのは何でしょうか？

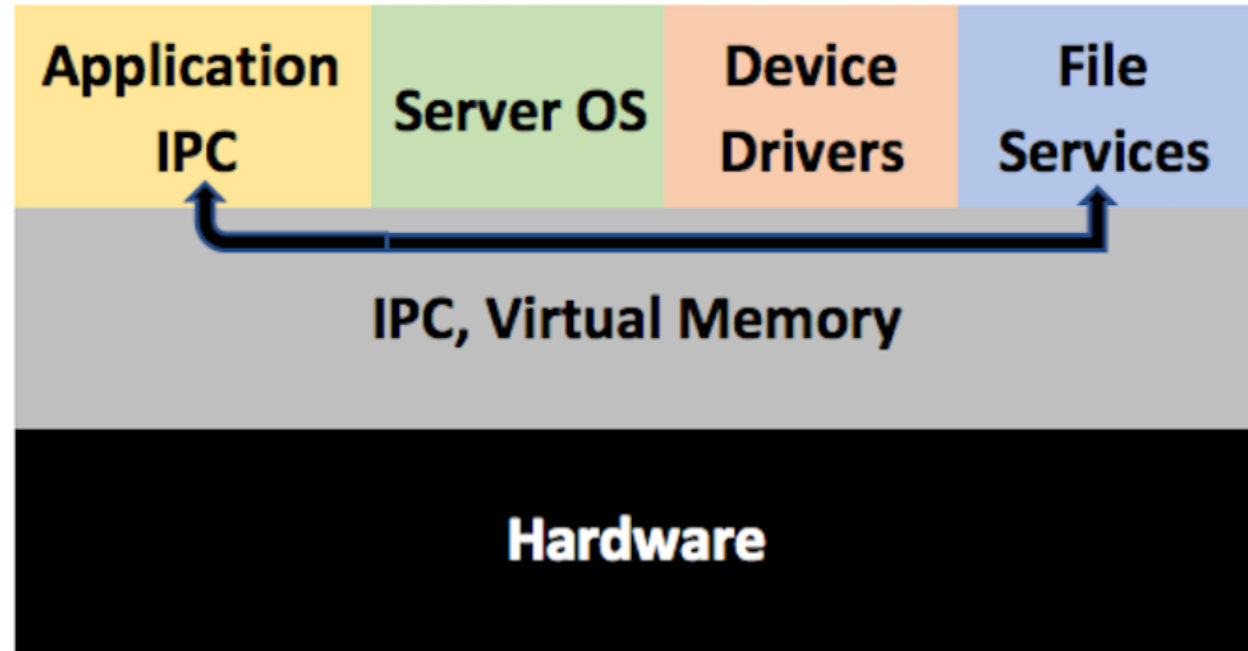
- ☐ ジェフのアカウントはローカル管理者グループには含まれていますが、ローカルポリシーグループには含まれていません。
- ☐ DCSベンダーは、ローカルポリシーへの不正な改ざんを防止するために、カスタムプログラムコードを適用しました。
- ☒ **ワークステーションには、ローカルセキュリティポリシーを上書きするドメインベースのポリシーが適用されています。**
- ☐ ワークステーションの更新設定が間違っているため、ポリシーが適用されていません。

✓ その通りです

ドメインベースのポリシー設定は、ローカルのセキュリティポリシー設定を上書きできます。ローカル管理者アカウントがあれば、セキュリティポリシー設定を変更できます。DCSベンダーは推奨ポリシー設定を提供することが多いですが、OSを変更するような非公開のカスタムプログラムコードは提供しません。更新設定は、設定変更や新しい設定の適用を制限しません。

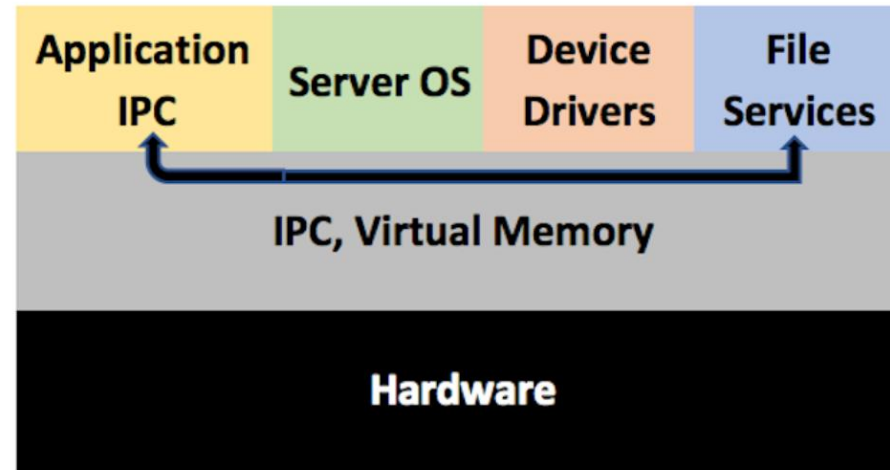
Question 47 of 82

The diagram below demonstrates the operation of which of the following?



- ☐ Monolithic kernel OS
- ☐ Virtual machine guest
- ☒ **Virtual machine hypervisor**
- ☐ Microkernel OS

以下の図は、次のうちどれの動作を示していますか？



- ☐ モノリシックカーネルOS
- ☐ 仮想マシンゲスト
- ☒ 仮想マシンハイパーバイザー
- ☒ マイクロカーネルOS

✖ あなたは間違っています

モノリシックカーネル（例えば、Windows OSのフルインストール）とは異なり、マイクロカーネルは、基本的なプロセス間通信（IPC）、仮想メモリ、スケジューリングといった機能を担うことが多い。モノリシックOSではカーネルレベルで行われるようなその他の一般的な操作は、マイクロカーネルOSではユーザーランドプログラムとして実行され、ドライバやファイル管理などの処理を担当する。

Question 48 of 82

Which of the following can assist in implementing single sign-on authentication by using a ticketing system?



Kerberos



Biometrics



RADIUS



LDAP

全82問中48問目

チケットシステムを使用してシングルサインオン認証を実装する際に役立つのは、次のうちどれですか？

- ☒ **ケルベロス**
- ☐ 生体認証
- ☐ 半径
- ☐ LDAP

☒ **その通りです**

Kerberosはチケットシステムを使用してユーザーを認証します。LDAPは認証完了後に認可を提供します。RADIUSはチケットシステムを使用しません。

Question 49 of 82

Which of the following would be used to hide a private network from an outside network?



NAT



ACL



DNS



DHCP

全82問中49問目

プライベートネットワークを外部ネットワークから隠蔽するために使用されるのは、次のうちどれですか？

☒ **NAT** 6e13b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ ACL

☐ DNS

☐ DHCP

☒ **その通りです**

プライベートネットワークのアドレス空間を隠蔽するために用いられる技術は、ネットワークアドレス変換（NAT）と呼ばれる。

アクセス制御リストはアドレスを隠蔽しません。

DNSは、名前をIPアドレスに解決するサーバーです。

DHCPはネットワーク内のIPアドレスを管理します。

Question 50 of 82

What can be done to get malicious code to execute when a computer starts up?

- ☐ Use the BIOS to launch a script that calls it
- ☒ **Inject it into RAM memory**
- ☐ Use pagefile.sys to launch it
- ☐ Use filesystem slack space to store it
- ☐ Place it in the boot sector

全82問中50問目

コンピュータの起動時に悪意のあるコードを実行させるには、どのような方法がありますか？

- ☐ BIOSを使用して、それを呼び出すスクリプトを起動します。
- ☒ **RAMメモリに注入する**
- ☐ pagefile.sys を使用して起動します。
- ☐ ファイルシステムの空き領域を使用して保存します。
- ☒ **ブートセクターに配置してください**

☒ あなたは間違っています

BIOSはスクリプトの呼び出しには使用できず、pagefile.sysは物理メモリがいっぱいになった場合にのみアクセスされ、RAMメモリはマシンの電源サイクルごとにクリアされます。また、悪意のあるコードはスラック領域に格納できますが、自動的に起動することはありません。ブートセクタ内のコードは、OSが起動するたびに実行されます。

Question 51 of 82

According to the DHS suggested patch decision tree, what should a security team do after it is determined that a vulnerability affects their ICS?

- ☐ Determine if there is a work-around available
- ☐ Analyze the vulnerability footprint
- ☐ Determine if the operational needs are greater than the risk
- ☒ **Analyze the impact to the business needs and operations**

国土安全保障省が提案するパッチ適用決定ツリーによると、セキュリティチームは脆弱性が産業制御システム（ICS）に影響を与えることが判明した場合、どのような対応を取るべきでしょうか？

- 6e137b03-99b1-41d8-bedd-29c33c3a25ba (14232740)
- ☒ 回避策があるかどうかを確認する
 - ☐ 脆弱性の痕跡を分析する
 - ☐ 運用上のニーズがリスクを上回るかどうかを判断する
 - ☒ ビジネスニーズと業務への影響を分析する

× あなたは間違っています

チームは、脆弱性がICSに影響を与えるかどうかを判断する必要があります。影響がない場合は、通常どおり運用を継続できますが、影響がある場合は、回避策が利用可能かどうかを判断する必要があります。回避策が利用可能な場合は、予定されているアップデート期間が利用可能になるまで、その回避策を使用できます。回避策がない場合は、運用上のニーズがリスクよりも大きいかどうかをチームが判断する必要があります。この判断には、ビジネスニーズと運用への影響、および脆弱性のフットプリントを分析する必要があります（脆弱性がICSに影響を与えるかどうかを判断した後の2つの判断）。

Question 52 of 82

What is a recommended guideline to follow when setting up a secure ICS network architecture?

- ☐ Do not set up a trust between Active Directory domains on the control network and the Enterprise network
- ☒ **Place simple proxies in the ICS DMZ to keep them separate from systems in the control network**
- ☐ Move any onsite servers that communicate with the cloud for control systems to the ICS DMZ
- ☐ Use the same jump hosts for employees and vendors

安全なICSネットワークアーキテクチャを構築する際に推奨されるガイドラインは何ですか？

- ☒ **コントロールネットワークとエンタープライズネットワーク上のActive Directoryドメイン間で信頼関係を構築しないでください。**
- ☒ **シンプルなプロキシをICS DMZに配置して、制御ネットワーク内のシステムから分離します。**
- ☐ 制御システムのためにクラウドと通信するオンプレミスサーバーをすべてICS DMZに移動します。
- ☐ 従業員とベンダーには同じジャンプホストを使用する

× あなたは間違っています

安全な ICS ネットワーク アーキテクチャを構築するための推奨サイバー セキュリティ ガイドラインには、次のものが含まれます。1) 単純なプロキシは脆弱性を盲目的に通過させるため使用を避ける、2) エンタープライズとの信頼関係を持たない制御ネットワーク用の別の AD ドメインを設定する、3) 制御ネットワークのクラウドに接続するオンサイト サーバーを ICS DMZ に配置せず、別の DMZ に配置する、4) リモートで制御ネットワークにアクセスする各従業員またはベンダーは、それぞれのニーズに応じて異なるジャンプホストを使用する。

Question 53 of 82

Corporate cyber security policies within an organization should be treated in which of the following ways for ICS environments?

- ☐ Implemented as is
- ☒ **Customized for ICS environments**
- ☐ Only implemented in ICS test environments
- ☐ Never implemented in ICS environments

全82問中53問目

組織内の企業サイバーセキュリティポリシーは、ICS環境において、以下のどの方法で扱うべきでしょうか？

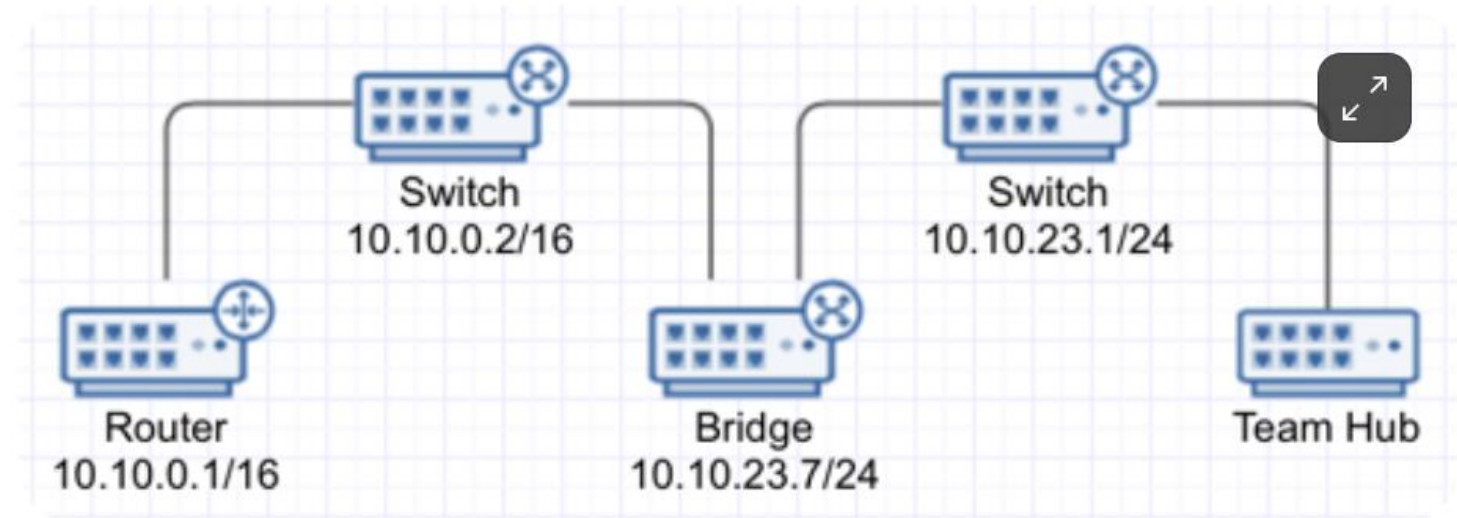
- ☐ 現状のまま実装
- ☒ **ICS環境向けにカスタマイズ**
- ☐ ICSテスト環境でのみ実装されています
- ☐ ICS環境では実装されたことがない

☒ **その通りです**

企業のサイバーセキュリティポリシーには多くの重要な要素が含まれているが、ICS環境に合わせてカスタマイズする必要がある。

Question 54 of 82

Observe the devices below; which network device will drop Layer 2 broadcast traffic?

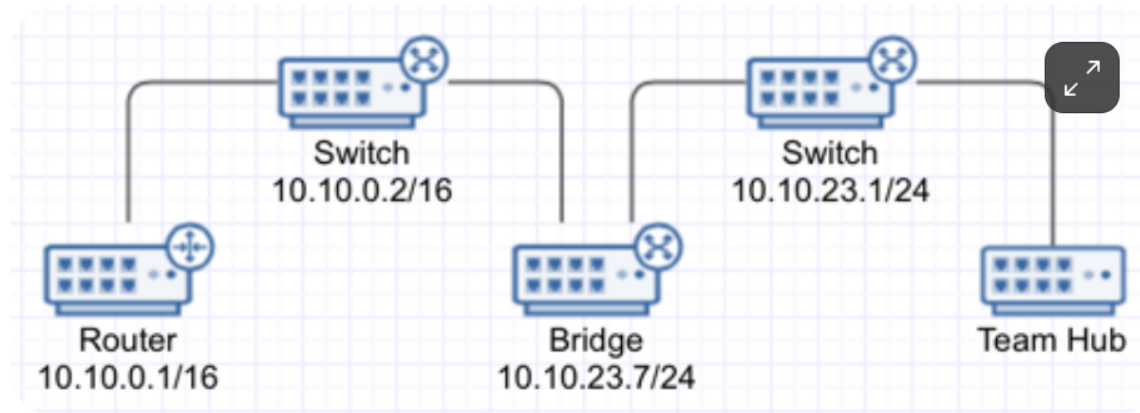


☒ **Router** 6e137b05-99b7-4fd8-bedd-29c33c5a25ba (14232740)

- ☐ Hub
- ☐ Bridge
- ☐ Switch

全82問中54問目

以下のデバイスを観察してください。どのネットワークデバイスがレイヤ2ブロードキャストトラフィックをドロップしますか？



☒ ルーター

☐ ハブ

☐ 橋

☐ スイッチ

☒ その通りです

ルーターはレイヤー3で動作し、パケット転送時にIPアドレスを参照します。ルーターはデフォルトではMACレベル（レイヤー2）のトラフィックをすべて破棄します。スイッチとブリッジはMACレベルの情報をを使用してトラフィックを切り替えます。ハブは、1つのポートで受信したトラフィックを、稼働中のすべてのポートに単純に中継します。

Question 55 of 82

Which of the following mechanisms is designed for centrally collecting records of local events from field devices and many other systems?

☒ **syslog** 6e157b05-99b7-4fd8-bedd-29c33c5a25ba (14232740)

- ☐ netlog
- ☐ iptables
- ☐ Kerberos

以下のメカニズムのうち、現場機器やその他の多くのシステムからローカルイベントの記録を一元的に収集するように設計されているのはどれですか？

☒ **syslog** 6e137b03-99b1-4fd8-bedd-29c33c5a25ba (14232740)

- ☐ ネットログ
- ☐ iptables
- ☐ ケルベロス

☒ **その通りです**

syslogプロトコルは、組み込みフィールドデバイスとサーバーやワークステーションなどの従来のITインフラストラクチャの両方で広くサポートされており、ネットワーク経由でログデータを収集し、中央の場所で分析することができます。Kerberosプロトコルは、認証、認可、アカウントティング（AAA）の集中管理に使用され（そのため、アクセス要求の失敗をログに記録して報告できます）、リモートデバイスに保存されている既存のログデータやイベントデータを収集する機能はありません。「netlog」オプションは架空のログ記録メカニズムであり、ベルギーに拠点を置く同名のソーシャルネットワーキングサイトとは一切関係ありません。最後に、iptablesはLinuxシステムのファイアウォールメカニズムであり、ログ記録/イベント管理システムではありません。

Question 56 of 82

Which level of the Purdue Enterprise Reference Architecture (PERA) groups systems that support site-wide operations?

- ☐ 3
- ☒ 4
- ☐ 2
- ☐ 5

全82問中56問目

Purdue Enterprise Reference Architecture (PERA) のどのレベルで、サイト全体の運用をサポートするシステムがグループ化されていますか？

☒ 3
6e1577b03-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☒ 4

☐ 2

☐ 5

✕ あなたは間違っています

パデューモデルでは、システムを0から4までの5つの異なるレベルに分割することを提案しています。レベル0は最も低いレベルで、物理的なプロセスを表し、そのグループのプロセスを構成する直接的なセンサーとアクチュエータが含まれます。レベル1には、そのグループのプロセスのコントローラが含まれます。レベル2には、各グループのプロセスに固有のローカル監視システムが含まれます。プロセスグループの上には、工場全体または地域全体のレベル3があり、そのサイトまたはその地域のすべてのプロセスグループを制御する監視システムが含まれます。レベル3には、運用をサポートするシステムで構成されますが、プロセスのリアルタイム実行には直接関与しない運用サポートも含まれます。レベル4は、ICSに関連する組織のビジネス面を表します。パデューモデルの現代的な進化では、多くの場合、すべての企業ビジネスユニットに対するエンタープライズサポートを表すレベル5が含まれます。

Question 57 of 82

What is a benefit of an integrated SIS over a traditional SIS?

- ☐ Increase in reliability
- ☒ **Reduction in equipment costs**
- ☐ Increase in system robustness
- ☐ Reduction in probability of safety event

全82問中57問目

統合型SISは、従来型SISに比べてどのような利点がありますか？

- ☐ 信頼性の向上
- ☒ 設備コストの削減
- ☐ システムの堅牢性の向上
- ☐ 安全事象発生確率の低減

☒ その通りです

統合型SISは配線が少なく、追加のハードウェアも不要です。

Question 58 of 82

An organization has been vulnerable to a specific CVE for two years. Last week a metasploit module was released to exploit the vulnerability in an automated fashion. What happened to the vulnerability?

- 6e137b05-99b1-41d8-bedd-29c33c5a25ba (14232740)
- ☒ **It increased**
 - ☐ It changed categories
 - ☐ It decreased
 - ☐ It remained the same

全82問中58問目

ある組織は、2年間特定のCVEに対して脆弱な状態に置かれていました。先週、その脆弱性を自動的に悪用するMetasploitモジュールがリリースされました。この脆弱性はどうなったのでしょうか？

☒ 増加した 6e137b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ カテゴリーが変わりました

☐ 減少した

☒ それは変わらなかった

☒ あなたは間違っています

脆弱性は不変であり、存在するか存在しないかのどちらかです。既存の脆弱性は、パッチ適用などの何らかの対策によって解消できます。脆弱性に関連するリスクは、増加、減少、またはカテゴリーの変更が生じる可能性があります、それは脆弱性自体が変化するのではなく、リスク計算における他の変数が変化するためです。

Question 59 of 82

What is the Annualized Loss Expectancy (ALE) for a \$300,000 asset with an exposure factor of 25% and an Annualized Rate Occurrence of 6?

- ☐ \$450,000
- ☐ \$200,000
- ☐ \$50,000
- ☒ **\$75,000**

全82問中59問目

エクスポージャー係数が25%、年間発生率が6の30万ドルの資産に対する年間損失期待値（ALE）はいくらですか？

☒ 45万ドル

☐ 20万ドル

☐ 5万ドル

☒ 75,000ドル

☒ あなたは間違っています

$$\text{ALE} = \text{AV} * \text{EF} * \text{ARO}$$

$$\text{ALE} = \$300,000 * 25\% * 6$$

$$\text{ALE} = \$75,000 * 6$$

$$\text{ARO} = \$450,000$$

Question 60 of 82

Which of the following describes the concept of Culture of Compliance?

- ☐ Use of Compliance Gap Assessments to measure issues in situations in which policies are not being followed
- ☐ Beginning with leadership, an understanding of the importance of policies and support for them throughout the organization
- ☒ **Routine review of policies to ensure they are tracking with the current direction of the organization**
- ☐ Utilization of compliance controls that ensure policies are effectively implemented and shortcomings are tracked and corrected

全82問中60問目

次のうち、コンプライアンス文化の概念を説明しているのはどれですか？

- ☐ コンプライアンスギャップ評価を用いて、ポリシーが遵守されていない状況における問題点を測定する
- ☒ リーダーシップから始まり、組織全体で方針の重要性を理解し、それを支持することが重要である。
- ☒ 組織の現在の方向性と合致していることを確認するための定期的な方針の見直し
- ☐ 法令遵守管理を活用し、法令が効果的に実施され、不備が追跡・是正されることを保証する。

× あなたは間違っています

これらはすべて、方針の採用と企業方針との整合性を促進する方法を説明しています。コンプライアンス文化とは、組織のリーダーシップによって推進され、組織全体で方針が広く受け入れられ、その重要性が理解される文化的な状態を指します。

Question 61 of 82

Which of the following locations would be the Unix equivalent of \Program Files?

- ☒ /etc
- ☐ /boot
- ☐ /usr
- ☐ /root
- ☐ /dev

全82問中61問目

以下の場所のうち、Unix における \Program Files に相当するものはどれですか？

☒ **/等**
6e137b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ /ブート

☒ **/usr**

☐ /根

☐ /dev

☒ **あなたは間違っています**

/usr はサードパーティ製アプリケーションファイルが格納されている場所です。/root はルートユーザーのホームディレクトリです。/etc は設定ディレクトリです。/dev はデバイスファイルです。/boot はカーネルファイルです。

Question 62 of 82

Which of the following is the most direct threat to an air-gapped system?

- ☐ Fuzzing attack
- ☐ Internet worm known to attack ICS systems
- ☐ Phishing attack
- ☐ ARP spoofing attack
- ☒ **USB thumb drive containing malware**

全82問中62問目

エアギャップシステムにとって最も直接的な脅威となるのは次のうちどれですか？

- ☐ ファジング攻撃
- ☐ ICSシステムを攻撃することが知られているインターネットワーム
- ☐ フィッシング攻撃
- ☐ ARPスプーフィング攻撃
- ☒ マルウェアを含むUSBメモリ

✓ その通りです

高度な攻撃は、もともとUSBメモリを介して導入されたと言われており、悪意のある活動を行うためにシステムに物理的にアクセスすることの有効性を示しています。また、注目を集めた事件では、論理的に分離されたネットワークやエアギャップされたネットワークでさえ、このような攻撃に対して無敵ではないことが証明されています。遠隔地の施設の通信や機器を侵害するという概念も、決して新しいものではありません。セキュリティ専門家は、企業顧客向けに承認されたネットワーク侵入テストを実施する際に、しばしばこのような戦術を用います。

その他の攻撃はすべて、攻撃者がネットワーク上に存在することを前提としており、これはエアギャップによって防止されるべきである。

Question 63 of 82

What is a characteristic of Windows Group Policy Objects (GPOs)?

- ☐ Deployed automatically using Active Directory
- ☐ Overwritten by Local Security Policies
- ☒ **Requires computer be rebooted to apply**

全82問中63問目

Windowsグループポリシーオブジェクト（GPO）の特徴は何ですか？

- ☒ **Active Directoryを使用して自動的にデプロイされます**
- ☐ ローカルセキュリティポリシーによって上書きされます
- ☒ **適用するにはコンピュータの再起動が必要です**

× あなたは間違っています

グループポリシーを使用してセキュリティテンプレートを展開するには、対象のマシンがドメインに参加している必要があります。GPOは、Windows Active Directoryを使用して自動的に展開できます。グループポリシーオブジェクトはローカルセキュリティポリシーよりも優先され、gpmc.mscやgpedit.mscなどのツールを使用して管理できます。secedit.exeは、Active Directoryドメインに参加していないマシンのセキュリティポリシーを管理するためのツールです。GPOは、起動時、ログオン時、および90～120分ごとに適用されます。

Question 64 of 82

Which of the following contains the logic and parameters for Programmable Logic Controllers (PLCs)?

- ☐ Project Files
- ☐ Human Machine Interface
- ☒ **Front End Processor**
- ☐ Historian

次のうち、プログラマブルロジックコントローラ（PLC）のロジックとパラメータが含まれているのはどれですか？

- ☒ プロジェクトファイル
- ☐ ヒューマンマシンインターフェース
- ☒ フロントエンドプロセッサ
- ☐ 歴史家

✖ あなたは間違っています

PLC が実行するタスクはハードコーディングされていません。名前が示すように、PLC の機能はプログラムで設定できます。エンジニアリングワークステーションによく保存されているプロジェクトファイルには、制御システム、ネットワークアーキテクチャ、構成、および PLC のロジックとパラメータの詳細が含まれています。そのため、攻撃者にとって格好の標的となります。ヒューマンマシンインターフェースは、オペレータにデータを提供しますが、自動化されたプロセスのロジックは含まれていません。ヒストリアンにはイベントログが含まれており、多くの場合 SQL データベースに保存されます。フロントエンドプロセッサは、RTU (リモートターミナルユニット) と管理システム間の通信を監視します。

Question 65 of 82

At which NIST Cybersecurity Framework (CSF) Tier is an organization that has approved practices that are not adopted widely throughout the organization?

- ☐ Tier 2 - Risk Informed
- ☐ Tier 1 - Partial
- ☒ **Tier 4 - Adaptive**
- ☐ Tier 3 - Repeatable

全82問中65問目

承認されたプラクティスが組織全体で広く採用されていない組織は、NISTサイバーセキュリティフレームワーク（CSF）のどのティアに該当しますか？

- ☒ **ティア2 - リスク情報に基づく**
- ☐ ティア1 - 部分的
- ☒ **ティア4 - 適応型**
- ☐ ティア3 - 繰り返し可能

✕ あなたは間違っています

ティア2では、リスク管理の実践は経営陣によって承認されているものの、組織全体のポリシーとして確立されていない可能性があります。組織レベルではサイバーセキュリティリスクに対する認識はありますが、サイバーセキュリティリスクを管理するための組織全体のアプローチは確立されていません。

Question 66 of 82

Maintaining the temperature within a specific range while producing chemicals or plastics is an example of which type of ICS process model?

☐ Continuous

☒ **Discrete**

☐ Batch

全82問中66問目

化学薬品やプラスチックを製造する際に、温度を特定の範囲内に維持することは、どのタイプのICSプロセスモデルの例でしょうか？

☒ 連続

☐ 離散

☐ バッチ

☐ あなたは間違っています

ICSの主なプロセスモデルは、離散型、バッチ型、連続型、ハイブリッド型の4つです。離散型モデルでは、指定された量の材料がワークステーション間を単位として移動し、各単位はプロセス全体を通して固有の識別情報を保持します。その一例として、金属プレス加工（ナンバープレート）が挙げられます。バッチ処理では、特定の量の原材料が特定の方法で一定期間混合され、中間製品または最終製品が生成されます。その一例として、接着剤や糊の製造が挙げられます。連続型モデルでは、温度などの変数が一定期間、特定の範囲（一定）に維持されます。このタイプの処理の例としては、化学薬品やプラスチックの製造が挙げられます。

Question 67 of 82

What type of attack attempts to overrun a device's resources?

- ☐ Session hijacking
- ☐ Privilege escalation
- ☒ **Denial of service**
- ☐ Machine in the middle

全82問中67問目

デバイスのリソースを過剰に利用しようとする攻撃の種類はどのようなものですか？

- ☐ セッションハイジャック
- ☐ 特権の拡大
- ☒ サービス拒否
- ☐ 中央の機械

✓ その通りです

サービス拒否攻撃の手法の一つとして、デバイスのネットワーク、CPU、メモリ、その他のリソースを過剰に利用して、サービス提供能力を低下させる方法があります。中間者攻撃（MIM）は、ユーザーに信頼できないリソースを使用させることで、隠された情報を漏洩させる攻撃です。権限昇格攻撃では、設計や構成上のエラーを悪用して、追加の権限を取得します。セッションハイジャックは、正当なユーザーを強制的にログアウトさせ、そのセッションを乗っ取ることを目的としています。

Question 68 of 82

What guideline should be followed when setting up a secure ICS network architecture?

- ☐ Enterprise Active Directory should not extend to level 4 (Business Network)
- ☐ Require traffic between the business and control networks to stop at a server in the DMZ
- ☐ Place patch management servers for the control networks in the ICS DMZ
- ☒ **Internet access should not go deeper than level 3 (Site-Wide Supervisory)**

全82問中68問目

安全なICSネットワークアーキテクチャを構築する際に、どのようなガイドラインに従うべきでしょうか？

- ☐ エンタープライズActive Directoryはレベル4（ビジネスネットワーク）まで拡張すべきではありません。
- ☒ **ビジネスネットワークと制御ネットワーク間のトラフィックをDMZ内のサーバーで停止させるようにする。**
- ☐ 制御ネットワーク用のパッチ管理サーバーをICS DMZに配置する
- ☒ **インターネットアクセスはレベル3（サイト全体の監視）より深いレベルまで到達させてはならない。**

☒ **あなたは間違っています**

安全なICSネットワークを構築するための推奨サイバーセキュリティガイドラインには、次のものが含まれます。1) インターネットアクセスと電子メールがレベル4より深く進まないこと、2) エンタープライズActive Directoryをレベル4より下に拡張しないこと、3) ビジネスネットワークと制御ネットワーク間のすべてのトラフィックがICS DMZ内のサーバーで停止するようにすること、4) 制御ネットワークのパッチ管理サーバーをパデューレベル3に配置すること。

Question 69 of 82

What can an attacker analyze to find cryptographic keys being transmitted by hardware?

- ☐ Clock timing
- ☐ Entropy levels
- ☒ **Fuzzy logic**
- ☐ FET transistors

全82問中69問目

攻撃者は、ハードウェアによって送信される暗号鍵を特定するために、どのような情報を分析できるのでしょうか？

- ☐ クロックタイミング
- ☒ エントロピーレベル
- ☒ ファジーロジック
- ☐ FETトランジスタ

✖ あなたは間違っています

エントロピーの急上昇は、暗号鍵が送信されていることを示している可能性がある。

Question 70 of 82

Which of the following protocols relies on three geostationary I-4 satellites and provides three different types of service?

- ☐ BGAN
- ☐ CDMA
- ☐ VSAT
- ☐ LTE
- ☒ **GSM**

全82問中70問目

以下のプロトコルのうち、3基の静止軌道I-4衛星を利用し、3種類の異なるサービスを提供するものはどれですか？

- 6e13-b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☒ **BGAN**
 - ☐ CDMA
 - ☐ VSAT
 - ☐ LTE
 - ☒ **GSM**

✕ あなたは間違っています

ブロードバンドグローバルエリアネットワーク（BGAN）はインマルサット社が提供しており、I-4と呼ばれる3基の静止衛星を使用してほぼ全世界をカバーしています。BGAN端末の利点の1つは、消費電力が低いことです（待機時4ワット、バースト送信時22ワット）。これは、待機時または送信時に90～150ワットを消費する衛星アンテナシステムよりもはるかに少ない電力です。

インマルサットが提供するサービスには、以下の3種類があります。

- ・インマルサットの標準BGANサービスは、インターネット、電話、SMS、ファックス、ISDN、ストリーミングサービスを提供します。
- ・2012年2月に開始されたBGAN M2Mサービスは、リモートSCADAまたはM2M（マシンツーマシン）機器の監視と制御のための低帯域幅サービスで、2、5、10、20メガバイトの月額サービスプラン（Hughes 9502 BGAN端末）で提供されます。
- ・2012年3月に開始されたBGAN Linkは、月間5～30ギガバイトのデータ転送を必要とする固定拠点向けです（クラス1 BGAN端末（Hughes 9201またはExplorer 700/710）でのみ利用可能です）。

Question 71 of 82

What advantage does the NIST CSF have over the ISO 27001 and ISA/IEC 62443 cybersecurity frameworks?

- ☒ **Is available to any organization without cost**
- ☐ Provides guidance on protecting third party information
- ☐ Applies to end-users, system integrators, and security personnel
- ☐ Is applicable to both large and small businesses
- ☐ Enables organizations meeting requirements to be certified

全82問中71問目

NIST CSFは、ISO 27001およびISA/IEC 62443サイバーセキュリティフレームワークと比較して、どのような利点がありますか？

☒ **どの組織でも無料で利用できます**

- ☐ 第三者情報の保護に関するガイダンスを提供する
- ☐ エンドユーザー、システムインテグレーター、およびセキュリティ担当者に適用されます。
- ☐ 大企業と中小企業の両方に適用可能
- ☐ 要件を満たす組織が認証を受けられるようにする

☒ **その通りです**

NIST CSFが他のサイバーセキュリティフレームワークよりも優れている点は、無料であることです。ISO 27001とISA/IEC 62443は無料ではありません。これら3つのフレームワークはすべて、組織が改善するためのロードマップを提供します。サイバーセキュリティフレームワークは、規模の大小を問わず、あらゆる組織がエンドユーザー、ハードウェア、ソフトウェア、プロセス、転送中のデータ、サービス、およびアプリケーションを保護するのに役立ちます。ISO 27001の基準に従って監査を正常に完了した組織は、認証を受けることができます。

Question 72 of 82

What is a similarity between the Modbus Remote Terminal Unit (RTU) protocol and the Modbus TCP protocol?

- ☐ Neither uses an IP header
- ☐ Neither supports more than one session at a time
- ☐ Both hex encode the request
- ☒ **Both use a transaction ID**

全82問中72問目

Modbusリモートターミナルユニット（RTU）プロトコルとModbus TCPプロトコルの類似点は何ですか？

- ☐ どちらもIPヘッダーを使用しない
- ☐ どちらも同時に複数のセッションをサポートしていません
- ☒ どちらもリクエストを16進数でエンコードします
- ☒ どちらもトランザクションIDを使用します

⊗ あなたは間違っています

Modbus RTUとModbus TCPはどちらもリクエストを16進数でエンコードします。Modbus RTUは一度に1つのセッションしかサポートしませんが、Modbus TCPは複数の通信を同時に行うことができるため、トランザクションIDを追加します。Modbus RTUはネットワーク層を持たないためIPヘッダーを使用しませんが、Modbus TCPはネットワーク層を使用するためIPヘッダーを追加します。

Question 73 of 82

How could an administrator apply security policies to Windows machines that are not part of an Active Directory domain?

- ☐ Delivering a template through Group Policy
- ☐ Using Windows Server Update Services (WSUS)
- ☒ **Delivering a template with secedit.exe**

全82問中73問目

管理者は、Active Directoryドメインに参加していないWindowsマシンにセキュリティポリシーをどのように適用できるのでしょうか？

- ☐ グループポリシーを通じてテンプレートを配信する
- ☐ Windows Server Update Services (WSUS) を使用する
- ☒ **secedit.exe を使用したテンプレートの配信**

☒ その通りです

secedit.exe は、Active Directory ドメインに参加していないマシンのセキュリティポリシーを更新できるコマンドラインツールです。スクリプト機能も備えているため、ネットワーク上の数百台のマシンのポリシーを更新するために使用できます。scw.exe は、古い Windows サーバーでマシンごとにセキュリティポリシーを構成するのに役立ちます。グループポリシーを使用してセキュリティテンプレートを展開するには、対象のマシンがドメインに参加している必要があります。WSUS は、Active Directory ドメインに参加しているシステムのパッチを一元管理するためのツールです。MECM も WSUS と同様にパッチを一元管理するために使用されますが、システムパフォーマンスの監視やインベントリ管理などの機能強化が施されています。

Question 74 of 82

Which of the following systems logged the Syslog event below?

Jan 23 03:12:41 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

☒ The host at 192.168.10.42

☐ The host named sshd

☐ The host at 192.168.10.13

☐ The host named admin

全82問中74問目

以下のシステムのうち、下記のSyslogイベントを記録したのはどれですか？

Jan 23 03:12:41 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

☒ **ホストは192.168.10.42です**

- ☐ sshdという名前のホスト
- ☐ ホストは192.168.10.13です
- ☐ adminという名前のホスト

☒ **その通りです**

日付/時刻スタンプの後に続くフィールド「ip-192-168-10-42」は、syslogエントリを送信したマシンです。sshdは、エントリを報告したプログラムの名前です。adminとIP 192.168.10.13はどちらもメッセージデータであり、この場合はログインを試みたアカウント名と、その試行が行われたIPアドレスを示しています。

Question 75 of 82

What recommended practice should vendors follow to protect passwords?

- ☒ **Prefer SMS based multi factor authentication over token based**
- ☐ Support distributed credential storage and management
- ☐ Do not restrict which special characters can be used
- ☐ Do not permit customer-based complexity requirements

ベンダーはパスワードを保護するために、どのような推奨事項に従うべきでしょうか？

- 6e15b05-99b1-4fd8-bedd-29c55c5a25ba (14252740)
- ☒ トークンベースの多要素認証よりもSMSベースの多要素認証を優先する
 - ☐ 分散型認証情報の保存と管理をサポートする
 - ☒ 使用できる特殊文字を制限しないでください
 - ☐ 顧客ベースの複雑性要件を許可しない

✕ あなたは間違っています

ベンダーは、パスワードを保護するために以下のガイドラインに従うべきです。まず、使用できる特殊文字を制限してはなりません。次に、トークンベースの多要素認証（MFA）よりもSMS認証を優先してはなりません。さらに、顧客が独自の複雑性要件を設定できるようにする必要があります。そして、ベンダーは集中認証をサポートし、1) 認証情報が複数の場所ではなく1か所で管理・保存され、2) ユーザーは1か所でパスワードを変更するだけで済み、3) ユーザーは複数の認証情報ではなく1セットの認証情報を記憶するだけで済むようにする必要があります。これらの対策により、ユーザーはアカウントを共有する必要がなくなります。

Question 76 of 82

Use PowerShell to list all services that have **Starttype** equal to **Manual** and pipe the output to **Measure-Object**. How many services are listed (the value of Count)?

[View VM](#)

- ☐ 66
- ☐ 281
- ☐ 63
- ☐ 253
- ☐ 175
- ☐ 92
- ☐ 82
- ☐ 83
- ☐ 134
- ☐ 46

Question 76 of 82

Use PowerShell to list all services that have **Starttype** equal to **Manual** and pipe the output to **Measure-Object**. How many services are listed (the value of **Count**)?

☐ 66
6e157b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)

☐ 281

☐ 63

☐ 253

☒ 175

☒ 92

☐ 82

☐ 83

☐ 134

☐ 46

StarttypePowerShell を使用して、と等しいすべてのサービスを一覧表示し **Manual**、その出力を にパイプします **Measure-Object**。一覧表示されるサービスの数 (**Count** の値) はいくつですか？

☒ You are incorrect

```
Get-Service | where Starttype -eq Manual | Measure-Object
```

Question 77 of 82

Use PowerShell to display all WMI objects and select strings that contain **user** in them. How many results are returned?

Hint: the output can be piped to "Measure-Object" to easily find the count.

[View VM](#)

- ☐ 47
- ☐ 72
- ☐ 18
- ☐ 20
- ☐ 60
- ☐ 25
- ☐ 94
- ☐ 13
- ☐ 91
- ☐ 48

PowerShellを使用してすべてのWMIオブジェクトを表示し、**user**それらに含まれる文字列を選択します。結果はいくつ返されますか？

ヒント：出力を「Measure-Object」にパイプすることで、簡単にカウントを取得できます。

- ☐ 47
- ☐ 72
- ☐ 18
- ☒ **20**
- ☐ 60
- ☐ 25
- ☐ 94
- ☐ 13
- ☐ 91
- ☐ 48

☒ **その通りです**

Get-WmiObject -List | Select-String user | Measure-Object

Question 78 of 82

Examine the control sheet found on the Desktop in the following directory structure:
Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio.

What is the Signal associated with the Flow Input bit tag?

[View VM](#)

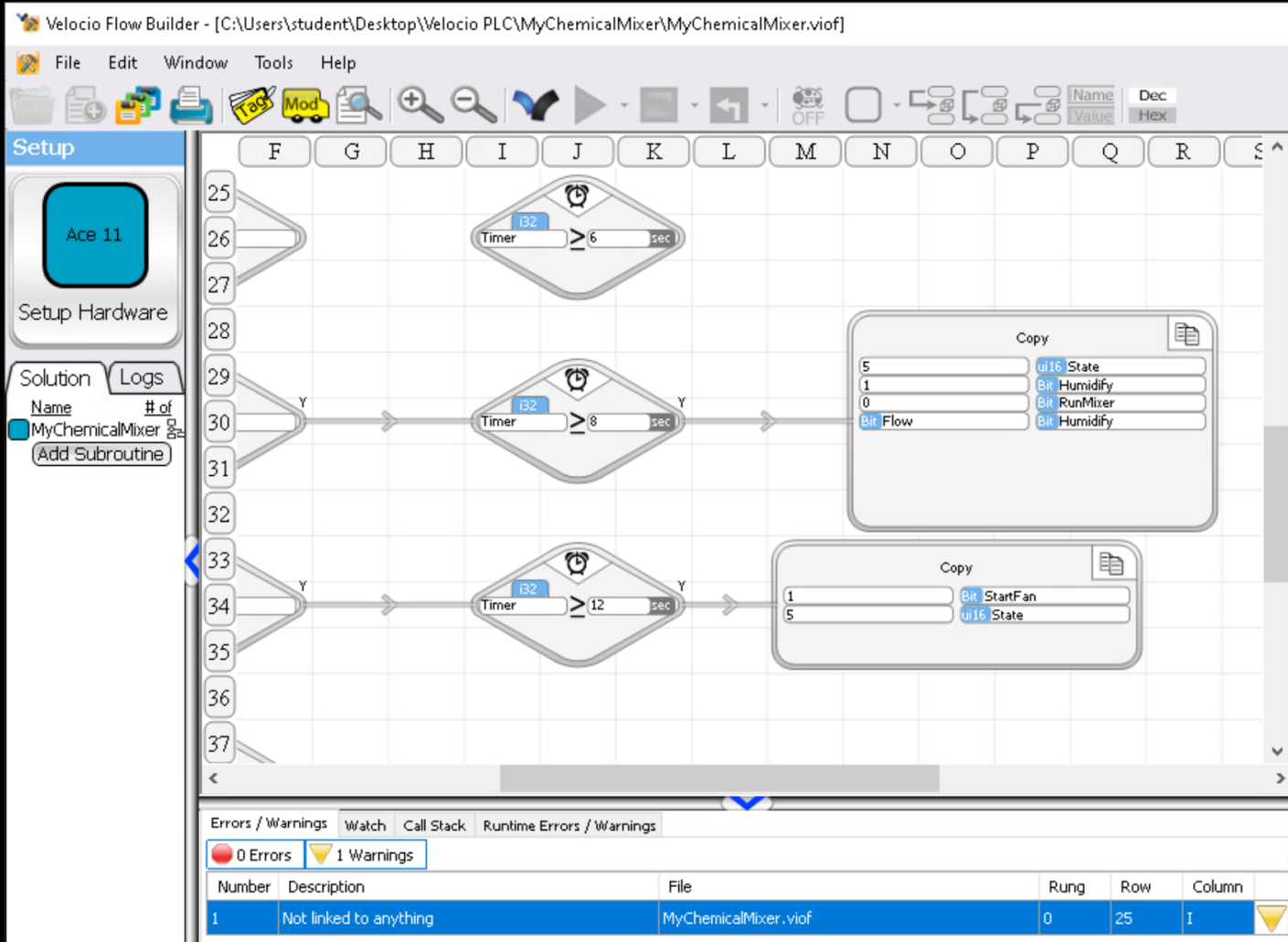
- ☐ C2
- ☐ CA
- ☐ C9
- ☐ C3
- ☐ C8
- ☐ C1
- ☐ C7
- ☐ C4
- ☐ C5
- ☐ C6

VMを終了する

環境をリセット

環境を更新

全画面表示



Toolbox

Wire Router

ON? OFF?

< >

≤ ≥

= ≠

< > ≥

Turn On/Off

+/- Calculator

Copy

Counter

Data Log

Filter

Motion In

Motion Out

PID

PWM

Ramp

Scale

Shift / Rotate

Statistics

Subroutine

Timer / Clock

Note

全82問中78問目

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

フロー入力ビットタグに関連付けられている信号は何ですか？

- ☐ C2
- ☐ カリフォルニア
- ☐ C9
- ☐ C3
- ☒ C8
- ☐ C1

回答を送信

お困りですか？

00:33:34

全82問中78問目

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

フロー入力ビットタグに関連付けられている信号は何ですか？

- 6e10b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☐ C2
 - ☐ カリフォルニア
 - ☐ C9
 - ☒ C3
 - ☒ C8
 - ☐ C1
 - ☐ C7
 - ☐ C4
 - ☐ C5
 - ☐ C6

✖ あなたは間違っています

Velocioの上部アイコンバーから「タグ」アイコンを選択してください。

表示されたダイアログから「入力ビット」を選択してください。

フロータグに関連付けられているシグナルを特定します。

Question 79 of 82

The file ~/GIAC/guitar.enc was encrypted using the following command and a passkey of **giacpass**. Decrypt the file's contents using Cyber Chef, what is the decrypted word?

```
openssl enc -aes-256-cbc -pbkdf2 -md sha512 -iter 10000 -S 0 -iv 0 -in guitar
```

Hint: Salt and IV will both be 16 characters long

[View VM](#)

☐ Di Meola

☐ Garcia

☐ McLaughlin

☐ Kessel

☐ Green

☐ Reinhardt

☐ De Lucia

☐ Hendrix

☐ Pass

☐ Page

1

de54 d8f7 4aa2 dc80 10b8 bdb5 91a9 b0f2

全82問中79問目

ファイル ~/GIAC/guitar.enc は、以下の
コマンドとパスキーを使用して暗号化
されました。Cyber Chef を使用
してファイルの内容を復号化すると、
復号化された単語は何ですか？

```
openssl enc -aes-256-cbc -pbkdf2 -md  
sha512 -iter 10000 -S 0 -iv 0 -in  
guitar
```

ヒント：SaltとIVはどちらも16文字で
す

- ☐ ディ・メオラ
- ☐ ガルシア
- ☐ マクラフリン

回答を送信

お困りですか？

00:27:56

Home

IAC

Open

1 de54 d8f7 4aa2

guit

men

CyberChef

file:///usr/local/share/cyberchef.htm

Version 7.5.1

Operations

Search...

Favourites

To Base64

From Base64

To Hex

From Hex

To Hexdump

From Hexdump

URL Decode

Regular expression

Entropy

Fork

Recipe

Input

length: 0

lines: 1

Clear I/O

Reset layout

Options

About

Support

de54 d8f7 4aa2 dc80 10b8 bdb5 91a9 b0f2

Output

time: 0ms

length: 0

lines: 1

Bake!

Auto Bake

Save recipe

Load recipe

Clear recipe

Step

Clear breaks

全82問中79問目

ファイル ~/GIAC/guitar.enc は、以下の
コマンドとパスキーを使用して暗号化
されました。Cyber Chefを使用
してファイルの内容を復号化すると、
復号化された単語は何ですか？

```
openssl enc -aes-256-cbc -pbkdf2 -md  
sha512 -iter 10000 -S 0 -iv 0 -in  
guitar
```

ヒント：SaltとIVはどちらも16文字で
す

- ☐ ディ・メオラ
- ☐ ガルシア
- ☐ マクラフリン

回答を送信

お困りですか？

00:24:39

ファイル~/GIAC/guitar.encは、以下のコマンドとパスキーを使用して暗号化された
したgiacpass。Cyber Chefを使用してファイルの内容を復号化すると、復号化され
た単語は何ですか?

```
openssl enc -aes-256-cbc -pbkdf2 -md sha512 -iter 10000 -S 0 -iv 0 -in guitar
```

ヒント：SaltとIVはどちらも16文字です

- ☐ デイ・メオラ
- ☐ ガルシア
- ☒ マクラフリン
- ☐ ケッセル
- ☐ 緑
- ☐ ラインハルト
- ☐ デ・ルシア
- ☐ ヘンドリックス
- ☒ 合格
- ☐ ページ

× あなたは間違っています

CyberChefでpbkdf2を検索し、暗号化の詳細に従ってパスフレーズと反復情報を入力します。

キーをコピー/レシピをクリア

aes復号化を検索して情報を入力してください

ファイルの内容を「入力」欄にコピー＆ペーストしてください。

焼いてください。

Question 80 of 82

Use xxd to examine ~/GIAC/memdump/dump2. Which ASCII character is represented at offset 0x80?

[View VM](#)

- ☐ *
- ☐ %
- ☐ (
- ☐)
- ☐ !
- ☐ @
- ☐ &
- ☐ \$
- ☐ ^
- ☐ +

```
Terminal
~ /GIAC/memdump
xxd dump2
00000000: 7f45 4c46 0101 0100 0000 0000 0000 0000 .ELF.....
00000010: 0200 0300 0100 0000 9c9e 0408 3400 0000 .....4...
00000020: 4cb2 0000 0000 0000 3400 2000 0900 2800 L.....4. ...(.
00000030: 1c00 1b00 0600 0000 3400 0000 3480 0408 .....4...4...
00000040: 3480 0408 2001 0000 2001 0000 0500 0000 4... ..
00000050: 0400 0000 0300 0000 5401 0000 5481 0408 .....T...T...
00000060: 5481 0408 1300 0000 1300 0000 0400 0000 T.....
00000070: 0100 0000 0100 0000 0000 0000 0080 0408 .....
00000080: 0080 0408 24a0 0000 24a0 0000 0500 0000 ....$...$.
00000090: 0010 0000 0100 0000 10af 0000 103f 0508 .....?..
000000a0: 103f 0508 4002 0000 3408 0000 0600 0000 .?..@...4.....
000000b0: 0010 0000 0200 0000 24af 0000 243f 0508 .....$...$?..
000000c0: 243f 0508 c800 0000 c800 0000 0600 0000 $?.....
000000d0: 0400 0000 0400 0000 6801 0000 6881 0408 .....h...h...
000000e0: 6881 0408 4400 0000 4400 0000 0400 0000 h...D...D.....
000000f0: 0400 0000 50e5 7464 6890 0000 6810 0508 ....P.tdh...h...
00000100: 6810 0508 cc02 0000 cc02 0000 0400 0000 h.....
00000110: 0400 0000 51e5 7464 0000 0000 0000 0000 ....Q.td.....
00000120: 0000 0000 0000 0000 0000 0000 0600 0000 .....
00000130: 0400 0000 52e5 7464 10af 0000 103f 0508 ....R.td.....?..
00000140: 103f 0508 f000 0000 f000 0000 0400 0000 .?.....
00000150: 0100 0000 2f6c 6962 2f6c 642d 6c69 6e75 .... /lib/ld-linu
```

ed. [Learn More](#)

Input length: 0 lines: 1 [Clear I/O](#) [Reset layout](#)

54 d8f7 4aa2 dc80 10b8 bdb5 91a9 b0f2

Options About / Support

Output time: 0ms length: 0 lines: 1 [Copy](#) [Paste](#) [Undo](#) [Redo](#) [Fullscreen](#)

Question 80 of 82

Use xxd to examine ~/GIAC/memdump/dump2. Which ASCII character is represented at offset 0x80?

- ☐ *
- ☐ %
- ☐ (
- ☐)
- ☐ !
- ☐ @
- ☐ &
- ☒ \$
- ☐ ^
- ☐ +

[Submit Answer](#)

[Need Help?](#)

00:19:34

全82問中80問目

xxd を使用して ~/GIAC/memdump/dump2 を調べます。オフセットにはどの ASCII 文字が表されていますか0x80？

- 6e137b05-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☐ *
 - ☐ %
 - ☐ (
 - ☐)
 - ☐ !
 - ☐ @
 - ☐ &
 - ☒ \$
 - ☐ ^
 - ☐ +

✓ その通りです

オフセットは出力の左側に表示されます。オフセットはファイルの先頭付近にあるため、lessgrepで検索する代わりに、単にスクロールしてオフセット位置まで移動すれば済みます。

Question 81 of 82

Use sqlmap to dump tables from <http://localhost/index.php?page=login.php>. The data necessary for this is as follows:

`user_name=j`

`password=p`

`Submit_button=Submit`

Which of the following is a table name in the dojo_control database?

Hint: The option to dump tables is --tables

View VM

- ☐ events
- ☐ files
- ☐ views
- ☐ statistics
- ☐ users
- ☐ index_statistics
- ☐ engines
- ☐ applicable_roles
- ☐ user_variables
- ☐ hitlog

CyberChef

file:///usr/local/share/cyberchef.htm

Terminal

```
| THREAD_POOL_WAITS
| TRIGGERS
| USER_PRIVILEGES
| USER_STATISTICS
| VIEWS
| user_variables
+-----+

Database: dojo_control
[3 tables]
+-----+
| accounts
| blogs_table
| hitlog
+-----+

[02:18:11] [INFO] fetched data logged to text files under '/home/control/.local/share/sqlmap/output/localhost'
[02:18:11] [WARNING] your sqlmap version is outdated

[*] ending @ 02:18:11 /2026-04-17/
```

~/GIAC/memdump

took 14s at 02:18:11

Question 81 of 82

Hint: The option to dump tables is --tables

- ☐ events
- ☐ files
- ☐ views
- ☐ statistics
- ☐ users
- ☐ index_statistics
- ☐ engines
- ☐ applicable_roles
- ☐ user_variables
- ☒ hitlog

Submit Answer

Need Help?

00:12:36

全82問中81問目

sqlmapを使用してからテーブルをダンプします `http://localhost/index.php?page=login.php`。これに必要なデータは次のとおりです。

`user_name=j`

`password=p`

`Submit_button=Submit`

dojo_controlデータベース内のテーブル名は、次のうちどれですか？

ヒント：テーブルをダンプするオプションは `--tables` です。

- ☐ イベント
- ☐ ファイル
- ☐ 閲覧数
- ☐ 統計
- ☐ ユーザー
- ☐ インデックス統計
- ☐ エンジン
- ☐ 適用可能な役割
- ☐ ユーザー変数
- ☒ ヒットログ

✔ その通りです

質問に記載されている情報は、sqlmap で以下のように使用できます。

```
sqlmap --fresh-queries -u "http://localhost/index.php?page=login.php" --data "user_name=j&password=p&submit_button=Submit" --tables
```

Question 82 of 82

Use Wireshark's I/O graph functionality to examine ~/GIAC/plantemonium.pcap. What time (in seconds since the start of capture) is closest to the spikes in Modbus traffic seen?

[View VM](#)

- ☐ 15000
- ☐ 150000
- ☐ 450000
- ☐ 45000
- ☐ 15
- ☐ 1500
- ☐ 4500
- ☐ 150
- ☐ 45
- ☐ 450

Activitieswireshark

Apr 17 02:20

FileEditViewGoCaptureAnalyzeStatistics

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination
1	0.000000	10.25.2...	10.25.22
2	0.000035	10.25.2...	10.25.22
3	0.000225	10.25.2...	10.25.22
4	0.000455	10.25.2...	10.25.22
5	0.000482	10.25.2...	10.25.22
6	0.000957	10.25.2...	10.25.22
7	0.003018	10.25.2...	10.25.22
8	0.003181	10.25.2...	10.25.22
9	0.003298	10.25.2...	10.25.22

Frame 1: 62 bytes on wire (496 bits), Ethernet II, Src: VMware_de:4f:d9 (00:0c:29:cb:da:ef), Dst: 08:00:27:de:4...

Wireshark · I/O Graphs · plantemonium.pcap

Wireshark I/O Graphs: plantemonium.pcap

No packets in interval (1.859e+05s).

Enabled	Graph Name	Display Filter	Color	Style	Y Axis	Y Field	SMA Period	Y Axis Factor
☒	TCP Errors	tcp.analysis...		Bar	Packets		None	1

+ -

Mouse ☒ drags ☐ zooms Interval 1 sec ☐ Time of day ☐ Log scale ☒ Automatic Update Reset

Help Copy Copy from Close Save As...

全82問中82問目

WiresharkのI/Oグラフ機能を使用して、~/GIAC/plantemonium.pcapを調べてください。Modbusトラフィックの急増に最も近い時刻（キャプチャ開始からの秒数）はいつですか？

☐ 15000

☒ 150000

☐ 450000

☐ 45000

☐ 15

☐ 1500

☐ 4500

☐ 150

回答を送信

お困りですか？

00:10:58

全82問中82問目

WiresharkのI/Oグラフ機能を使用して、~/GIAC/plantemonium.pcapを調べてください。Modbusトラフィックの急増に最も近い時刻（キャプチャ開始からの秒数）はいつですか？

- 6e157b03-99b1-4fd8-bedd-29c33c5a25ba (14232740)
- ☐ 15000
 - ☒ 150000
 - ☐ 450000
 - ☐ 45000
 - ☐ 15
 - ☐ 1500
 - ☐ 4500
 - ☐ 150
 - ☐ 45
 - ☐ 450

✓ その通りです

表示フィルタとして「Modbus」を追加します。[統計] > [I/Oグラフ]を開きます。

この場合、トラフィックの大部分はModbusなので、フィルタリングされていないトラフィックとModbusのみのトラフィックは非常に似ています。

終了しました

練習 失敗

得点：46 %（不合格）

続く



GICSP模擬試験

試験問題

合計：82

回答済み：82

ステータス：失敗

あなたのスコア：46 %

最低合格点：71%

完了日：2026年4月17日

CyberLive認証バイパス



CyberLiveバイナリファイル解析



サイバーライブ暗号化



CyberLiveエンドポイントのセキュリティ強化、ベースライン、ログ



CyberLiveフィールドバスプロトコル分析



CyberLive産業交通分析



エンドポイントの強化と保護



ICSコンポーネントとアーキテクチャ



ICSの概要と概念



ICSプログラムおよび政策開発



情報収集と脅威モデリング



PERAレベル0および1の技術概要と侵害



PERAレベル2および3の技術概要とリスク



プロトコル、コミュニケーション、そして妥協



リスクベースの災害復旧およびインシデント対応



無線技術とその限界

